Scan Report

January 26, 2026

Summary

This document reports on the results of an automatic security scan. All dates are displayed using the timezone "Coordinated Universal Time", which is abbreviated "UTC". The task was " hgdfdghgdgd". The scan started at Mon Jan 26 01:47:47 2026 UTC and ended at Mon Jan 26 14:04:13 2026 UTC. The report first summarises the results found. Then, for each host, the report describes every issue found. Please consider the advice given in each description, in order to rectify the issue.

Contents

1 Result Overview **2**

1.1 Host Authentications 2

2 Results per Host **2**

2.1 172.30.4.1 2

2.1.1 Critical 445/tcp 3

2.1.2 High 445/tcp 9

2.1.3 Medium 445/tcp 41

2.1.4 Low general/tcp 77

2.1.5 Low 445/tcp 78

2.1.6 Low general/icmp 80

2.1.7 Log general/tcp 81

2.1.8 Log 445/tcp 83

2.1.9 Log 139/tcp 87

2.1.10 Log general/CPE-T 88

1 Result Overview

Host	Critical	High	Medium	Low	Log	False P.
172.30.4.1 sambacry.trabalho_vulnnet	5	23	28	3	14	0
Total: 1	5	23	28	3	14	0

Vendor security updates are not trusted.
Overrides are off. Even when a result has an override, this report uses the actual threat of the result.
Information on overrides is included in the report.
Notes are included in the report.
This report might not show details of all issues that were found.
Issues with the threat level "Debug" are not shown.

This report contains all 73 results selected by the filtering described above. Before filtering there were 5586 results.

1.1 Host Authentications

Host	Protocol	Result	Port/User
172.30.4.1 - sambacry.trabalho_vulnnet	SMB	Success	Protocol SMB, Port 445, User

2 Results per Host

2.1 172.30.4.1

Host scan start	Mon Jan 26 01:48:40 2026 UTC
Host scan end	Mon Jan 26 03:33:50 2026 UTC

Service (Port)	Threat Level
445/tcp	Critical
445/tcp	High
445/tcp	Medium
general/tcp	Low
445/tcp	Low
general/icmp	Low
general/tcp	Log
445/tcp	Log
139/tcp	Log
general/CPE-T	Log

2.1.1 Critical 445/tcp

Critical (CVSS: 10.0)
NVT: Samba Command Injection Vulnerability (CVE-2025-10230)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to a command injection vulnerability via WINS server hook script.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.21.9
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.21.9, 4.22.5, 4.23.2 or later.

Affected Software/OS
Samba version 4.x prior to 4.21.9, 4.22.x prior to 4.22.5 and 4.23.x prior to 4.23.2.

Vulnerability Insight
If a Samba server has WINS support enabled (it is off by default), and it has a 'wins hook' parameter specified, the program specified by that parameter will be run whenever a WINS name is changed.
The WINS server used by the Samba Active Directory Domain Controller did not validate the names passed to the wins hook program, and it passed them by inserting them into a string run by a shell.
WINS is an obsolete and trusting protocol, and clients can request any name that fits within the 15 character NetBIOS limit. This includes some shell metacharacters, making it possible to run arbitrary commands on the host.
The WINS server used by Samba when it is not a domain controller is unaffected.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Command Injection Vulnerability (CVE-2025-10230)`
OID:1.3.6.1.4.1.25623.1.0.155661
Version used: `2025-11-10T05:40:50Z`

. . . continues on next page . . .

. . . continued from previous page . . .

Product Detection Result
Product: cpe:/a:samba:samba:4.5.9
Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
cve: CVE-2025-10230
url: https://www.samba.org/samba/security/CVE-2025-10230.html
url: https://www.samba.org/samba/history/samba-4.21.9.html
url: https://www.samba.org/samba/history/samba-4.22.5.html
url: https://www.samba.org/samba/history/samba-4.23.2.html
url: https://lists.samba.org/archive/samba-announce/2025/000704.html
url: https://github.com/dptsec/CVE-2025-10230
cert-bund: WID-SEC-2025-2322
dfn-cert: DFN-CERT-2026-0218
dfn-cert: DFN-CERT-2025-2874

Critical (CVSS: 10.0)
NVT: Samba End of Life (EOL) Detection

Product detection result
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)

Summary
The Samba version on the remote host has reached the end of life (EOL) and should not be used anymore.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
The "Samba" version on the remote host has reached the end of life.
CPE: cpe:/a:samba:samba:4.5.9
Installed version: 4.5.9
Location/URL: 445/tcp
EOL version: 4.5
EOL date: 2018-03-13

Impact
An EOL version of Samba is not receiving any security updates from the vendor. Unfixed security vulnerabilities might be leveraged by an attacker to compromise the security of this host.

Solution:
Solution type: VendorFix

. . . continues on next page . . .

. . . continued from previous page . . .

Update the Samba version on the remote host to a still supported version.

Vulnerability Detection Method
Checks if an EOL version is present on the target host.
Details: `Samba End of Life (EOL) Detection`
OID:1.3.6.1.4.1.25623.1.0.140159
Version used: `2025-04-15T05:54:49Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`url: https://wiki.samba.org/index.php/Samba_Release_Planning`

Critical (CVSS: 9.8)
NVT: Samba RCE Vulnerability (SambaCry)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to a remote code execution (RCE) vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.5.10 or apply patch
Installation
path / port:       445/tcp
```

Impact
Successfully exploiting this issue will allow remote attackers to execute arbitrary code as root on an affected system.

Solution:
Solution type: VendorFix
Upgrade to Samba 4.6.4 or 4.5.10 or 4.4.14 or later.

. . . continues on next page . . .

. . . continued from previous page . . .

Affected Software/OS
All Samba Server versions 3.5.0 onwards,
Samba Server versions 4.4.x before 4.4.14,
Samba Server versions 4.5.x before 4.5.10, and
Samba Server versions 4.6.x before 4.6.4

Vulnerability Insight
The flaw exists due to an input validation error, which allows a malicious client to upload a shared library to a writable share.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba RCE Vulnerability (SambaCry)`
OID:1.3.6.1.4.1.25623.1.0.811055
Version used: `2025-09-17T05:39:26Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2017-7494
cisa: Known Exploited Vulnerability (KEV) catalog
url: https://www.cisa.gov/known-exploited-vulnerabilities-catalog
url: https://www.samba.org/samba/security/CVE-2017-7494.html
url: http://www.securityfocus.com/bid/98636
url: http://hackaday.com/2017/05/25/linux-sambacry/
url: http://thehackernews.com/2017/05/samba-rce-exploit.html
url: https://github.com/omri9741/cve-2017-7494
cert-bund: CB-K17/1719
cert-bund: CB-K17/0879
dfn-cert: DFN-CERT-2017-1801
dfn-cert: DFN-CERT-2017-0906
```

Critical (CVSS: 9.8)
NVT: Samba Server 'CVE-2017-14746' Use-after-free Vulnerability

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to a use-after-free vulnerability.

. . . continues on next page . . .

. . . continued from previous page . . .

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.5.15
Installation
path / port:       445/tcp
```

Impact

A malicious SMB1 request can be used to control the contents of heap memory via a deallocated heap pointer. It is possible this may be used to compromise the SMB server.

Solution:

Solution type: VendorFix

Update to Samba 4.5.15, 4.6.11, 4.7.3 or later. Workaround:
Prevent SMB1 access to the server by setting the parameter:
server min protocol = SMB2
to the [global] section of your smb.conf and restart smbd. This prevents a SMB1 access to the server. Note this could cause older clients to be unable to connect to the server.

Affected Software/OS

Samba versions 4.0.0 to 4.5.14, 4.6.x prior to 4.6.11, 4.7.x prior to 4.7.3 with enabled SMBv1 support.

Vulnerability Insight

The flaw exists due to a client which may use an SMB1 request to manipulate the contents of heap space.

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.
Details: `Samba Server 'CVE-2017-14746' Use-after-free Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.108294
Version used: `2025-09-17T05:39:26Z`

Product Detection Result

Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2017-14746
url: https://www.samba.org/samba/security/CVE-2017-14746.html
url: http://www.securityfocus.com/bid/101907
cert-bund: CB-K18/0478
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: CB-K17/2077
cert-bund: CB-K17/2003
dfn-cert: DFN-CERT-2018-1603
dfn-cert: DFN-CERT-2018-0985
dfn-cert: DFN-CERT-2018-0513
dfn-cert: DFN-CERT-2017-2172
dfn-cert: DFN-CERT-2017-2095
```

Critical (CVSS: 9.8)
NVT: Samba Elevation of Privilege Vulnerability (CVE-2022-45141)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to an elevation of privilege vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.15.13 / 4.16.0
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.15.13, 4.16.0 or later.

Affected Software/OS

Samba versions prior to 4.15.13.

Vulnerability Insight

Kerberos, the trusted third party authentication system at the heart of Active Directory, issues a ticket using a key known to the target server but nobody else, returned to the client in a TGS-REP.

This key needs to be of a type understood only by the KDC and target server.

However, due to a coding error subsequently addressed in all recent Heimdal versions and so fixed with Samba 4.16 (which imports Heimdal 8.0pre), the (attacking) client would be given the opportunity to select the encryption type, and so obtain a ticket encrypted with rc4-hmac, that it could attack offline.

. . . continues on next page . . .

. . . continued from previous page . . .

This is possible unless rc4-hmac is totally removed from the server's account, by removing the unicodePwd attribute, but this will break other aspects of the server's operation in the domain (NETLOGON in particular).

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Elevation of Privilege Vulnerability (CVE-2022-45141)`
OID:1.3.6.1.4.1.25623.1.0.104475
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2022-45141`
`url: https://www.samba.org/samba/security/CVE-2022-45141.html`
`cert-bund: WID-SEC-2022-2365`
`dfn-cert: DFN-CERT-2025-1637`
`dfn-cert: DFN-CERT-2022-2870`

[return to 172.30.4.1]

2.1.2 High 445/tcp

High (CVSS: 8.8)
NVT: Samba Impersonation Vulnerability (CVE-2022-0336)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to an impersonation vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 4.5.9
Fixed version:     4.13.17
Installation
path / port:       445/tcp
```

. . . continues on next page . . .

. . . continued from previous page . . .

Impact
An attacker who has the ability to write to an account can exploit this to perform a denial of service (DoS) attack by adding an SPN that matches an existing service. Additionally, an attacker who can intercept traffic can impersonate existing services, resulting in a loss of confidentiality and integrity.

Solution:
Solution type: VendorFix
Update to version 4.13.17, 4.14.12, 4.15.5 or later.

Affected Software/OS
Samba version 4.0.0 through 4.13.16, 4.14.x through 4.14.11 and 4.15.x through 4.15.4.

Vulnerability Insight
The Samba AD DC includes checks when adding service principals names (SPNs) to an account to ensure that SPNs do not alias with those already in the database. Some of these checks are able to be bypassed if an account modification re-adds an SPN that was previously present on that account, such as one added when a computer is joined to a domain.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Impersonation Vulnerability (CVE-2022-0336)`
OID:1.3.6.1.4.1.25623.1.0.147556
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2022-0336`
`url: https://www.samba.org/samba/security/CVE-2022-0336.html`
`cert-bund: WID-SEC-2022-1335`
`cert-bund: WID-SEC-2022-1228`
`cert-bund: WID-SEC-2022-0466`
`cert-bund: WID-SEC-2022-0432`
`cert-bund: WID-SEC-2022-0302`
`cert-bund: CB-K22/0128`
`dfn-cert: DFN-CERT-2022-0865`
`dfn-cert: DFN-CERT-2022-0557`
`dfn-cert: DFN-CERT-2022-0348`
`dfn-cert: DFN-CERT-2022-0264`
`dfn-cert: DFN-CERT-2022-0242`

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2022-0239
dfn-cert: DFN-CERT-2022-0228
```

High (CVSS: 8.8)
NVT: Samba 4.x Multiple Vulnerabilities (CVE-2018-1050, CVE-2018-1057)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.5.16
Installation
path / port:       445/tcp
```

Impact

Successful exploitation would result in effects ranging from Denial of Service to Privilege Escalation, eventually allowing an attacker to gain full control over the target system.

Solution:

Solution type: VendorFix

Update to version 4.5.16, 4.6.14 or 4.7.6 respectively.

Affected Software/OS

Samba 4.x.x before 4.5.16, 4.6.x before 4.6.14 and 4.7.x before 4.7.6.

Vulnerability Insight

There exist two vulnerabilities:
- CVE-2018-1050: Samba is vulnerable to a denial of service attack when the RPC spoolss service is configured to be run as an external daemon. Missing input sanitization checks on some of the input parameters to spoolss RPC calls could cause the print spooler service to crash.
- CVE-2018-1057: On a Samba AD DC the LDAP server in Samba incorrectly validates permissions to modify passwords over LDAP allowing authenticated users to change any other users' passwords, including administrative users and privileged service accounts (eg Domain Controllers).

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.

. . . continues on next page . . .

. . . continued from previous page . . .

Details: Samba 4.x Multiple Vulnerabilities (CVE-2018-1050, CVE-2018-1057)
OID:1.3.6.1.4.1.25623.1.0.113133
Version used: 2021-06-22T11:00:29Z

Product Detection Result
Product: cpe:/a:samba:samba:4.5.9
Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
cve: CVE-2018-1050
cve: CVE-2018-1057
url: https://www.samba.org/samba/security/CVE-2018-1050.html
url: https://www.samba.org/samba/security/CVE-2018-1057.html
cert-bund: CB-K18/0894
cert-bund: CB-K18/0514
cert-bund: CB-K18/0443
dfn-cert: DFN-CERT-2019-0726
dfn-cert: DFN-CERT-2019-0069
dfn-cert: DFN-CERT-2018-2212
dfn-cert: DFN-CERT-2018-1786
dfn-cert: DFN-CERT-2018-1644
dfn-cert: DFN-CERT-2018-1603
dfn-cert: DFN-CERT-2018-0985
dfn-cert: DFN-CERT-2018-0550
dfn-cert: DFN-CERT-2018-0482

High (CVSS: 8.8)
NVT: Samba Buffer Overflow Vulnerability (CVE-2022-42898)

Product detection result
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)

Summary
Samba is prone to a buffer overflow vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
Installed version: 4.5.9
Fixed version: 4.15.12 / 4.16.7 / 4.17.3
Installation
path / port: 445/tcp

. . . continues on next page . . .

. . . continued from previous page . . .

Solution:
Solution type: VendorFix
Update to version 4.15.12, 4.16.7, 4.17.3 or later.

Affected Software/OS
Samba versions prior to 4.15.12, 4.16.x prior to 4.16.7 and 4.17.x prior to 4.17.3 on 32-bit systems.

Vulnerability Insight
Samba's Kerberos libraries and AD DC failed to guard against integer overflows when parsing a PAC on a 32-bit system, which allowed an attacker with a forged PAC to corrupt the heap.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Buffer Overflow Vulnerability (CVE-2022-42898)`
OID:1.3.6.1.4.1.25623.1.0.104423
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2022-42898`
`url: https://www.samba.org/samba/security/CVE-2022-42898.html`
`cert-bund: WID-SEC-2024-0794`
`cert-bund: WID-SEC-2023-2690`
`cert-bund: WID-SEC-2023-2031`
`cert-bund: WID-SEC-2023-1812`
`cert-bund: WID-SEC-2023-1737`
`cert-bund: WID-SEC-2023-1542`
`cert-bund: WID-SEC-2023-1424`
`cert-bund: WID-SEC-2023-1021`
`cert-bund: WID-SEC-2022-2372`
`cert-bund: WID-SEC-2022-2057`
`dfn-cert: DFN-CERT-2025-1637`
`dfn-cert: DFN-CERT-2023-2536`
`dfn-cert: DFN-CERT-2023-1592`
`dfn-cert: DFN-CERT-2023-1230`
`dfn-cert: DFN-CERT-2023-1162`
`dfn-cert: DFN-CERT-2023-0199`
`dfn-cert: DFN-CERT-2023-0089`
`dfn-cert: DFN-CERT-2022-2804`
`dfn-cert: DFN-CERT-2022-2657`

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2022-2612
dfn-cert: DFN-CERT-2022-2603
dfn-cert: DFN-CERT-2022-2579
```

High (CVSS: 8.8)
NVT: Samba RCE Vulnerability (CVE-2021-44142)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to a remote code execution (RCE) vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.13.17
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.13.17, 4.14.12, 4.15.5 or later.

Affected Software/OS

Samba versions prior to 4.13.17, version 4.14.x through 4.14.11 and 4.15.x through 4.15.4.

Vulnerability Insight

Samba is vulnerable to an out-of-bounds heap read write vulnerability that allows remote attackers to execute arbitrary code as root on affected Samba installations that use the VFS module vfs_fruit.

The specific flaw exists within the parsing of EA metadata when opening files in smbd. Access as a user that has write access to a file's extended attributes is required to exploit this vulnerability. Note that this could be a guest or unauthenticated user if such users are allowed write access to file extended attributes.

The problem in vfs_fruit exists in the default configuration of the fruit VFS module using fruit:metadata=netatalk or fruit:resource=file. If both options are set to different settings than the default values, the system is not affected by the security issue.

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.

Details: `Samba RCE Vulnerability (CVE-2021-44142)`

. . . continues on next page . . .

. . . continued from previous page . . .

OID:1.3.6.1.4.1.25623.1.0.147554
Version used: 2022-02-25T03:03:32Z

Product Detection Result
Product: cpe:/a:samba:samba:4.5.9
Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
cve: CVE-2021-44142
url: https://www.samba.org/samba/security/CVE-2021-44142.html
cert-bund: WID-SEC-2022-1335
cert-bund: WID-SEC-2022-1228
cert-bund: WID-SEC-2022-0466
cert-bund: WID-SEC-2022-0432
cert-bund: WID-SEC-2022-0302
cert-bund: CB-K22/0128
dfn-cert: DFN-CERT-2022-0557
dfn-cert: DFN-CERT-2022-0348
dfn-cert: DFN-CERT-2022-0332
dfn-cert: DFN-CERT-2022-0264
dfn-cert: DFN-CERT-2022-0242
dfn-cert: DFN-CERT-2022-0239
dfn-cert: DFN-CERT-2022-0232
dfn-cert: DFN-CERT-2022-0228

High (CVSS: 8.8)
NVT: Samba 'libsmbclient' Heap Buffer Overflow Vulnerability (Aug 2018)

Product detection result
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)

Summary
Samba is prone to a heap based buffer overflow vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
Installed version: 4.5.9
Fixed version: 4.6.16 or apply patch
Installation
path / port: 445/tcp

. . . continues on next page . . .

. . . continued from previous page . . .

Impact
Successful exploitation will allow an attacker to conduct a denial of service attack.

Solution:
Solution type: VendorFix
Update to version 4.6.16, 4.7.9 or 4.8.4 or later. Please see the references for more information.

Affected Software/OS
Samba versions 3.2.0 through 4.8.3.

Vulnerability Insight
The flaw exists due to insufficient input validation on client directory listing in libsmbclient.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 'libsmbclient' Heap Buffer Overflow Vulnerability (Aug 2018)`
OID:1.3.6.1.4.1.25623.1.0.813782
Version used: `2021-09-29T12:07:39Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2018-10858`
`url: https://www.samba.org/samba/security/CVE-2018-10858.html`
`url: https://www.samba.org/samba/history/samba-4.6.16.html`
`url: https://www.samba.org/samba/history/samba-4.7.9.html`
`url: https://www.samba.org/samba/history/samba-4.8.4.html`
`cert-bund: CB-K18/0894`
`cert-bund: CB-K18/0866`
`dfn-cert: DFN-CERT-2019-0420`
`dfn-cert: DFN-CERT-2018-2249`
`dfn-cert: DFN-CERT-2018-2212`
`dfn-cert: DFN-CERT-2018-1806`
`dfn-cert: DFN-CERT-2018-1786`
`dfn-cert: DFN-CERT-2018-1644`
`dfn-cert: DFN-CERT-2018-1608`
`dfn-cert: DFN-CERT-2018-1603`
`dfn-cert: DFN-CERT-2018-1598`
`dfn-cert: DFN-CERT-2018-1597`
`dfn-cert: DFN-CERT-2018-1594`

High (CVSS: 8.8)
NVT: Samba Multiple Vulnerabilities (Jul 2022)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.14.14 / 4.15.9 / 4.16.4
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.14.14, 4.15.9, 4.16.4 or later.

Affected Software/OS
Samba versions prior to 4.14.14, 4.15.x prior to 4.15.9 and 4.16.x prior to 4.16.4.

Vulnerability Insight
The following flaws exist:
- CVE-2022-2031: Samba AD users can bypass certain restrictions associated with changing passwords
- CVE-2022-32742: Server memory information leak via SMB1
- CVE-2022-32746: Samba AD users can induce a use-after-free in the server process with an LDAP add or modify request

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Multiple Vulnerabilities (Jul 2022)`
OID:1.3.6.1.4.1.25623.1.0.104259
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

. . . continues on next page . . .

. . . continued from previous page . . .

```
cve: CVE-2022-2031
cve: CVE-2022-32742
cve: CVE-2022-32746
url: https://www.samba.org/samba/security/CVE-2022-2031.html
url: https://www.samba.org/samba/security/CVE-2022-32742.html
url: https://www.samba.org/samba/security/CVE-2022-32746.html
cert-bund: WID-SEC-2022-0842
dfn-cert: DFN-CERT-2024-1065
dfn-cert: DFN-CERT-2023-0713
dfn-cert: DFN-CERT-2023-0199
dfn-cert: DFN-CERT-2023-0153
dfn-cert: DFN-CERT-2023-0089
dfn-cert: DFN-CERT-2022-2804
dfn-cert: DFN-CERT-2022-2514
dfn-cert: DFN-CERT-2022-1686
dfn-cert: DFN-CERT-2022-1674
dfn-cert: DFN-CERT-2022-1662
```

High (CVSS: 8.8)
NVT: Samba Privilege Escalation Vulnerability (CVE-2022-32744)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to a privilege escalation vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.14.14 / 4.15.9 / 4.16.4
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.14.14, 4.15.9, 4.16.4 or later.

Affected Software/OS

Samba versions starting from 4.3 and prior to 4.14.14, 4.15.x prior to 4.15.9 and 4.16.x prior to 4.16.4.

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Insight
Tickets received by the kpasswd service were decrypted without specifying that only that service's own keys should be tried. By setting the ticket's server name to a principal associated with their own account, or by exploiting a fallback where known keys would be tried until a suitable one was found, an attacker could have the server accept tickets encrypted with any key, including their own.
A user could thus change the password of the Administrator account and gain total control over the domain. Full loss of confidentiality and integrity would be possible, as well as of availability by denying users access to their accounts.
In addition, the kpasswd service would accept tickets encrypted by the krbtgt key of an RODC, in spite of the fact that RODCs should not have been able to authorise password changes.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Privilege Escalation Vulnerability (CVE-2022-32744)`
OID:1.3.6.1.4.1.25623.1.0.104257
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2022-32744
url: https://www.samba.org/samba/security/CVE-2022-32744.html
cert-bund: WID-SEC-2022-0842
dfn-cert: DFN-CERT-2024-2191
dfn-cert: DFN-CERT-2023-0199
dfn-cert: DFN-CERT-2023-0089
dfn-cert: DFN-CERT-2022-2804
dfn-cert: DFN-CERT-2022-1686
dfn-cert: DFN-CERT-2022-1662
```

High (CVSS: 8.8)
NVT: Samba 4.0.0 < 4.13.14, 4.14.0 < 4.14.10, 4.15.0 < 4.15.2 Multiple Vulnerabilities

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to multiple vulnerabilities.

. . . continues on next page . . .

. . . continued from previous page . . .

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.13.14
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.13.14, 4.14.10, 4.15.2 or later.

Affected Software/OS
Samba version 4.x through 4.13.13, 4.14.x through 4.14.9 and 4.15.x through 4.15.1.

Vulnerability Insight
The following vulnerabilities exist:
- CVE-2020-25718: Samba AD DC does not correctly sandbox Kerberos tickets issued by an RODC
- CVE-2020-25719: Samba AD DC does not always rely on the SID and PAC in Kerberos tickets
- CVE-2020-25721: Kerberos acceptors need easy access to stable AD identifiers (eg objectSid)
- CVE-2020-25722: Samba AD DC does not do suffienct access and conformance checking of data stored
- CVE-2021-3738: Use after free in Samba AD DC RPC server

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 4.0.0 < 4.13.14, 4.14.0 < 4.14.10, 4.15.0 < 4.15.2 Multiple Vulnerabiliti.`
↪..
OID:1.3.6.1.4.1.25623.1.0.147123
Version used: `2023-10-20T16:09:12Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2020-25722
cve: CVE-2021-3738
cve: CVE-2020-25718
cve: CVE-2020-25719
cve: CVE-2020-25721
url: https://www.samba.org/samba/security/CVE-2020-25718.html
url: https://www.samba.org/samba/security/CVE-2020-25719.html
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
url: https://www.samba.org/samba/security/CVE-2020-25721.html
url: https://www.samba.org/samba/security/CVE-2020-25722.html
url: https://www.samba.org/samba/security/CVE-2021-3738.html
cert-bund: WID-SEC-2022-2279
cert-bund: WID-SEC-2022-0432
cert-bund: WID-SEC-2022-0302
cert-bund: CB-K21/1173
dfn-cert: DFN-CERT-2022-0332
dfn-cert: DFN-CERT-2021-2625
dfn-cert: DFN-CERT-2021-2566
dfn-cert: DFN-CERT-2021-2539
dfn-cert: DFN-CERT-2021-2330
```

High (CVSS: 8.1)
NVT: Samba Man in the Middle Security Bypass Vulnerability (Heimdal)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to a MITM authentication validation bypass vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.5.12
Installation
path / port:       445/tcp
```

Impact

Successfully exploiting this issue will allow a MITM attacker to impersonate a trusted server and thus gain elevated access to the domain by returning malicious replication or authorization data.

Solution:

Solution type: VendorFix

Upgrade to Samba 4.6.6 or 4.5.12 or 4.4.15 or later or apply the patch from below.

Affected Software/OS

All versions of Samba from 4.0.0 before 4.6.6 or 4.5.12 or 4.4.15.

Note: All versions of Samba from 4.0.0 onwards using embedded Heimdal Kerberos. Samba binaries built against MIT Kerberos are not vulnerable.

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Insight
The flaw is due to error in function '_krb5_extract_ticket' where the KDC-REP service name must be obtained from encrypted version stored in 'enc_part' instead of the unencrypted version stored in 'ticket'. Use of the unencrypted version provides an opportunity for successful server impersonation and other attacks.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Man in the Middle Security Bypass Vulnerability (Heimdal)`
OID:1.3.6.1.4.1.25623.1.0.811522
Version used: `2025-09-17T05:39:26Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2017-11103
url: https://www.samba.org/samba/security/CVE-2017-11103.html
url: http://www.securityfocus.com/bid/99551
url: https://www.samba.org/samba/security
cert-bund: WID-SEC-2025-0370
cert-bund: CB-K17/2224
cert-bund: CB-K17/1854
cert-bund: CB-K17/1622
cert-bund: CB-K17/1585
cert-bund: CB-K17/1429
cert-bund: CB-K17/1398
cert-bund: CB-K17/1167
dfn-cert: DFN-CERT-2017-2325
dfn-cert: DFN-CERT-2017-1925
dfn-cert: DFN-CERT-2017-1692
dfn-cert: DFN-CERT-2017-1655
dfn-cert: DFN-CERT-2017-1494
dfn-cert: DFN-CERT-2017-1462
dfn-cert: DFN-CERT-2017-1206
```

High (CVSS: 8.1)
NVT: Samba Multiple Vulnerabilities (Dec 2022)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.15.13 / 4.16.8 / 4.17.4
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.15.13, 4.16.8, 4.17.4 or later.

Affected Software/OS
Samba versions prior to 4.15.13, 4.16.x prior to 4.16.8 and 4.17.x prior to 4.17.4.

Vulnerability Insight
The following flaws exist:
- CVE-2022-37966: rc4-hmac Kerberos session keys issued to modern servers
- CVE-2022-37967: Kerberos constrained delegation ticket forgery possible against Samba AD DC
- CVE-2022-38023: RC4/HMAC-MD5 NetLogon Secure Channel is weak and should be avoided

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Multiple Vulnerabilities (Dec 2022)`
OID:1.3.6.1.4.1.25623.1.0.104476
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2022-37966
cve: CVE-2022-37967
cve: CVE-2022-38023
url: https://www.samba.org/samba/security/CVE-2022-37966.html
url: https://www.samba.org/samba/security/CVE-2022-37967.html
url: https://www.samba.org/samba/security/CVE-2022-38023.html
cert-bund: WID-SEC-2024-0064
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: WID-SEC-2023-1737
cert-bund: WID-SEC-2022-2365
cert-bund: WID-SEC-2022-1983
dfn-cert: DFN-CERT-2023-1592
dfn-cert: DFN-CERT-2023-1311
dfn-cert: DFN-CERT-2023-1162
dfn-cert: DFN-CERT-2023-0286
dfn-cert: DFN-CERT-2023-0201
dfn-cert: DFN-CERT-2023-0199
dfn-cert: DFN-CERT-2023-0176
dfn-cert: DFN-CERT-2023-0153
dfn-cert: DFN-CERT-2023-0089
dfn-cert: DFN-CERT-2022-2870
dfn-cert: DFN-CERT-2022-2429
```

High (CVSS: 8.1)
NVT: Samba 3.0.0 < 4.13.14, 4.14.0 < 4.14.10, 4.15.0 < 4.15.2 Multiple Vulnerabilities

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.13.14
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.13.14, 4.14.10, 4.15.2 or later.

Affected Software/OS

Samba version 3.x and 4.x through 4.13.13, 4.14.x through 4.14.9 and 4.15.x through 4.15.1.

Vulnerability Insight

The following vulnerabilities exist:

- CVE-2016-2124: SMB1 client connections can be downgraded to plaintext authentication
- CVE-2020-25717: A user in an AD Domain could become root on domain members

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 3.0.0 < 4.13.14, 4.14.0 < 4.14.10, 4.15.0 < 4.15.2 Multiple Vulnerabiliti.`
`↪..`
OID:1.3.6.1.4.1.25623.1.0.147124
Version used: `2022-02-28T03:03:56Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2016-2124
cve: CVE-2020-25717
url: https://www.samba.org/samba/security/CVE-2016-2124.html
url: https://www.samba.org/samba/security/CVE-2020-25717.html
cert-bund: WID-SEC-2022-2279
cert-bund: WID-SEC-2022-1335
cert-bund: WID-SEC-2022-1228
cert-bund: WID-SEC-2022-0676
cert-bund: WID-SEC-2022-0530
cert-bund: WID-SEC-2022-0432
cert-bund: WID-SEC-2022-0302
cert-bund: CB-K21/1173
dfn-cert: DFN-CERT-2023-2166
dfn-cert: DFN-CERT-2022-1571
dfn-cert: DFN-CERT-2022-1469
dfn-cert: DFN-CERT-2022-0865
dfn-cert: DFN-CERT-2022-0369
dfn-cert: DFN-CERT-2022-0348
dfn-cert: DFN-CERT-2022-0332
dfn-cert: DFN-CERT-2022-0293
dfn-cert: DFN-CERT-2021-2566
dfn-cert: DFN-CERT-2021-2539
dfn-cert: DFN-CERT-2021-2488
dfn-cert: DFN-CERT-2021-2424
dfn-cert: DFN-CERT-2021-2412
dfn-cert: DFN-CERT-2021-2330
```

High (CVSS: 7.5)
NVT: Samba Multiple Vulnerabilities (Jul 2023)

Product detection result

. . . continues on next page . . .

. . . continued from previous page . . .

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.16.11 / 4.17.10 / 4.18.5
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.16.11, 4.17.10, 4.18.5 or later.

Affected Software/OS
All versions of Samba up to 4.16.10, 4.17.9 and 4.18.4.

Vulnerability Insight
The following flaws exist:
- CVE-2022-2127: Out-Of-Bounds read in winbind AUTH_CRAP
- CVE-2023-34966: Samba Spotlight mdssvc RPC Request Infinite Loop Denial-of-Service Vulnerability
- CVE-2023-34967: Samba Spotlight mdssvc RPC Request Type Confusion Denial-of-Service Vulnerability
- CVE-2023-34968: Spotlight server-side Share Path Disclosure

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Multiple Vulnerabilities (Jul 2023)`
OID:1.3.6.1.4.1.25623.1.0.104872
Version used: `2023-10-13T05:06:10Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2022-2127
cve: CVE-2023-34966
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cve: CVE-2023-34967
cve: CVE-2023-34968
url: https://www.samba.org/samba/security/CVE-2022-2127.html
url: https://www.samba.org/samba/security/CVE-2023-34966.html
url: https://www.samba.org/samba/security/CVE-2023-34967.html
url: https://www.samba.org/samba/security/CVE-2023-34968.html
cert-bund: WID-SEC-2023-2910
cert-bund: WID-SEC-2023-1842
dfn-cert: DFN-CERT-2025-1637
dfn-cert: DFN-CERT-2024-1661
dfn-cert: DFN-CERT-2024-1065
dfn-cert: DFN-CERT-2024-0839
dfn-cert: DFN-CERT-2024-0519
dfn-cert: DFN-CERT-2024-0231
dfn-cert: DFN-CERT-2023-2818
dfn-cert: DFN-CERT-2023-1744
dfn-cert: DFN-CERT-2023-1741
dfn-cert: DFN-CERT-2023-1666
```

High (CVSS: 7.5)
NVT: Samba 4.x Multiple DoS Vulnerabilities (Mar 2021)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to multiple Denial of Service (DoS) vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.12.12
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.12.12, 4.13.5, 4.14.0 or later.

Affected Software/OS

Samba version 4.0 and later.

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Insight
The following flaws exist:
- CVE-2020-27840: Heap corruption via crafted DN strings. An anonymous attacker can crash the Samba AD DC LDAP server by sending easily crafted DNs as part of a bind request. More serious heap corruption is likely also possible.
- CVE-2021-20277: Out of bounds read in AD DC LDAP server. User-controlled LDAP filter strings against the AD DC LDAP server may crash the LDAP server.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 4.x Multiple DoS Vulnerabilities (Mar 2021)`
OID:1.3.6.1.4.1.25623.1.0.117278
Version used: `2021-08-25T12:01:03Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2020-27840
cve: CVE-2021-20277
url: https://www.samba.org/samba/security/CVE-2020-27840.html
url: https://www.samba.org/samba/security/CVE-2021-20277.html
cert-bund: CB-K21/0311
dfn-cert: DFN-CERT-2022-0242
dfn-cert: DFN-CERT-2021-1504
dfn-cert: DFN-CERT-2021-0906
dfn-cert: DFN-CERT-2021-0807
dfn-cert: DFN-CERT-2021-0689
dfn-cert: DFN-CERT-2021-0674
dfn-cert: DFN-CERT-2021-0617
```

High (CVSS: 7.5)
NVT: Samba DoS Vulnerability (CVE-2020-10704)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to a denial of service vulnerability.

Quality of Detection (QoD): 30%

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.10.15
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.10.15, 4.11.8, 4.12.2 or later.

Affected Software/OS
All versions of Samba since Samba 4.0.0.

Vulnerability Insight
A LDAP Denial of Service (stack overflow) was found in Samba AD DC. A deeply nested filter in an un-authenticated LDAP search can exhaust the LDAP server's stack memory causing a SIGSEGV.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba DoS Vulnerability (CVE-2020-10704)`
OID:1.3.6.1.4.1.25623.1.0.108813
Version used: `2021-08-11T08:56:08Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2020-10704
url: https://www.samba.org/samba/security/CVE-2020-10704.html
cert-bund: CB-K20/0626
cert-bund: CB-K20/0377
dfn-cert: DFN-CERT-2020-2567
dfn-cert: DFN-CERT-2020-2026
dfn-cert: DFN-CERT-2020-1578
dfn-cert: DFN-CERT-2020-0867
```

High (CVSS: 7.5)
NVT: Samba DoS Vulnerability (CVE-2020-10745)

Product detection result

. . . continues on next page . . .

. . . continued from previous page . . .

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to a denial of service vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.10.17
Installation
path / port:       445/tcp
```

Impact
Compression of replies to NetBIOS over TCP/IP name resolution and DNS packets (which can be supplied as UDP requests) can be abused to consume excessive amounts of CPU on the Samba AD DC (only).

Solution:
Solution type: VendorFix
Update to version 4.10.17, 4.11.11, 4.12.4 or later.

Affected Software/OS
Samba version 4.0.0 and later.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba DoS Vulnerability (CVE-2020-10745)`
OID:1.3.6.1.4.1.25623.1.0.144244
Version used: `2021-08-11T08:56:08Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2020-10745
url: https://www.samba.org/samba/security/CVE-2020-10745.html
cert-bund: CB-K20/0857
cert-bund: CB-K20/0657
dfn-cert: DFN-CERT-2020-2567
dfn-cert: DFN-CERT-2020-2026
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2020-1620
dfn-cert: DFN-CERT-2020-1578
dfn-cert: DFN-CERT-2020-1417
```

High (CVSS: 7.5)
NVT: Samba Multiple DoS Vulnerabilities (CVE-2020-10745, CVE-2020-14303)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to two denial-of-service vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.10.17
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.10.17, 4.11.11, 4.12.4 or later.

Affected Software/OS
All Samba versions since 4.0.0.

Vulnerability Insight
- Compression of replies to NetBIOS over TCP/IP name resolution and DNS packets (which can be supplied as UDP requests) can be abused to consume excessive amounts of CPU on the Samba AD DC (only). (CVE-2020-10745)
- The AD DC NBT server in Samba 4.0 will enter a CPU spin and not process further requests once it receives an empty (zero-length) UDP packet to port 137. (CVE-2020-14303)

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Multiple DoS Vulnerabilities (CVE-2020-10745, CVE-2020-14303)`
OID:1.3.6.1.4.1.25623.1.0.108814
Version used: `2021-08-11T08:56:08Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`

. . . continues on next page . . .

. . . continued from previous page . . .

Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2020-10745
cve: CVE-2020-14303
url: https://www.samba.org/samba/security/CVE-2020-10745.html
url: https://www.samba.org/samba/security/CVE-2020-14303.html
cert-bund: CB-K20/0857
cert-bund: CB-K20/0657
dfn-cert: DFN-CERT-2020-2567
dfn-cert: DFN-CERT-2020-2026
dfn-cert: DFN-CERT-2020-1758
dfn-cert: DFN-CERT-2020-1620
dfn-cert: DFN-CERT-2020-1578
dfn-cert: DFN-CERT-2020-1417
```

High (CVSS: 7.5)
NVT: Samba Server 'CVE-2017-15275' Heap Memory Information Leak

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to a heap memory information leak.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.5.15
Installation
path / port:       445/tcp
```

Impact

There is no known vulnerability associated with this error, but uncleared heap memory may contain previously used data that may help an attacker compromise the server via other methods. Uncleared heap memory may potentially contain password hashes or other high-value data.

Solution:
Solution type: VendorFix
Update to Samba 4.5.15, 4.6.11, 4.7.3 or later.

. . . continues on next page . . .

. . . continued from previous page . . .

Affected Software/OS
Samba versions 3.6.0 to 4.5.14, 4.6.x prior to 4.6.11, 4.7.x prior to 4.7.3.

Vulnerability Insight
The flaw exists due to the server which may return the contents of heap allocated memory to the client.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Server 'CVE-2017-15275' Heap Memory Information Leak`
OID:1.3.6.1.4.1.25623.1.0.108295
Version used: `2025-09-17T05:39:26Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2017-15275
url: https://www.samba.org/samba/security/CVE-2017-15275.html
url: http://www.securityfocus.com/bid/101908
cert-bund: CB-K18/0478
cert-bund: CB-K18/0019
cert-bund: CB-K17/2077
cert-bund: CB-K17/2003
dfn-cert: DFN-CERT-2018-1603
dfn-cert: DFN-CERT-2018-0985
dfn-cert: DFN-CERT-2018-0513
dfn-cert: DFN-CERT-2018-0036
dfn-cert: DFN-CERT-2017-2172
dfn-cert: DFN-CERT-2017-2095
```

High (CVSS: 7.5)
NVT: Samba AD DC Principal Modification Vulnerability (CVE-2018-16860)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to a user impersonation vulnerability.

. . . continues on next page . . .

. . . continued from previous page . . .

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.8.12
Installation
path / port:       445/tcp
```

Impact

This allows a man-in-the-middle attacker who can intercept the request to the KDC to modify the packet by replacing the user name (principal) in the request with any desired user name (principal) that exists in the KDC and replace the checksum protecting that name with a CRC32 checksum (which requires no prior knowledge to compute).
This would allow a S4U2Self ticket requested on behalf of user name (principal) user@EXAMPLE.COM to any service to be changed to a S4U2Self ticket with a user name (principal) of Administrator@EXAMPLE.COM. This ticket would then contain the PAC of the modified user name (principal).

Solution:
Solution type: VendorFix
Update to version 4.8.12, 4.9.8, 4.10.3 or later.

Affected Software/OS

All Samba versions since Samba 4.0.

Vulnerability Insight

S4U2Self is an extension to Kerberos used in Active Directory to allow a service to request a kerberos ticket to itself from the Kerberos Key Distribution Center (KDC) for a non-Kerberos authenticated user (principal in Kerboros parlance). This is useful to allow internal code paths to be standardized around Kerberos.
S4U2Proxy (constrained-delegation) is an extension of this mechanism allowing this impersonation to a second service over the network. It allows a privileged server that obtained a S4U2Self ticket to itself to then assert the identity of that principal to a second service and present itself as that principal to get services from the second service.
There is a flaw in Samba's AD DC in the Heimdal KDC. When the Heimdal KDC checks the checksum that is placed on the S4U2Self packet by the server to protect the requested principal against modification, it does not confirm that the checksum algorithm that protects the user name (principal) in the request is keyed.

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.
Details: `Samba AD DC Principal Modification Vulnerability (CVE-2018-16860)`
OID:1.3.6.1.4.1.25623.1.0.108575
Version used: `2025-09-17T05:39:26Z`

Product Detection Result

. . . continues on next page . . .

. . . continued from previous page . . .

Product: cpe:/a:samba:samba:4.5.9
Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2018-16860
url: https://www.samba.org/samba/security/CVE-2018-16860.html
cert-bund: WID-SEC-2022-1713
cert-bund: WID-SEC-2022-1712
cert-bund: CB-K19/0649
cert-bund: CB-K19/0644
cert-bund: CB-K19/0396
dfn-cert: DFN-CERT-2022-2269
dfn-cert: DFN-CERT-2019-1512
dfn-cert: DFN-CERT-2019-1511
dfn-cert: DFN-CERT-2019-1124
dfn-cert: DFN-CERT-2019-0955
```

High (CVSS: 7.5)
NVT: Samba Missing ACL Vulnerability (CVE-2020-25720)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to a missing access control list (ACL) vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.17.7
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.17.7 or later.

Affected Software/OS

Samba version starting from 4.1 and prior to 4.17.7.

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Insight
A vulnerability was found in Samba where a delegated administrator with permission to create objects in Active Directory can write to all attributes of the newly created object, including security-sensitive attributes, even after the object's creation. This issue occurs because the administrator owns the object due to the lack of an Access Control List (ACL) at the time of creation and later being recognized as the 'creator owner.' The retained significant rights of the delegated administrator may not be well understood, potentially leading to unintended privilege escalation or security risks.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Missing ACL Vulnerability (CVE-2020-25720)`
OID:1.3.6.1.4.1.25623.1.0.114865
Version used: `2024-11-26T07:35:52Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2020-25720`
`url: https://www.samba.org/samba/history/samba-4.17.7.html`
`url: https://bugzilla.samba.org/show_bug.cgi?id=14810`
`url: https://gitlab.com/samba-team/samba/-/merge_requests/2514`
`dfn-cert: DFN-CERT-2024-0519`

High (CVSS: 7.5)
NVT: Samba Multiple Vulnerabilities (Sep 2022)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 4.5.9
Fixed version:     4.17.0
Installation
path / port:       445/tcp
```

. . . continues on next page . . .

. . . continued from previous page . . .

Solution:
Solution type: VendorFix
Update to version 4.17.0 or later.

Affected Software/OS
Samba versions starting from 4.1 and prior to 4.17.0.

Vulnerability Insight
The following flaws exist:
- CVE-2022-1615: In Samba, GnuTLS gnutls_rnd() can fail and give predictable random values.
- CVE-2022-32743: Samba does not validate the Validated-DNS-Host-Name right for the dNSHostName attribute which could permit unprivileged users to write it.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Multiple Vulnerabilities (Sep 2022)`
OID:1.3.6.1.4.1.25623.1.0.104323
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2022-1615
cve: CVE-2022-32743
url: https://bugzilla.samba.org/show_bug.cgi?id=15103
url: https://gitlab.com/samba-team/samba/-/merge_requests/2644
url: https://bugzilla.samba.org/show_bug.cgi?id=14833
cert-bund: WID-SEC-2022-1229
cert-bund: WID-SEC-2022-1179
dfn-cert: DFN-CERT-2024-0231
dfn-cert: DFN-CERT-2023-2792
dfn-cert: DFN-CERT-2022-2000
```

High (CVSS: 7.4)
NVT: Samba Server 'SMB3' MitM Vulnerability (CVE-2017-12151)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
Samba is prone to a MitM vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.4.16, or 4.5.14, or 4.6.8
Installation
path / port:       445/tcp
```

Impact
Successful exploitation will allow a remote attacker to read and/or alter the content of the connection.

Solution:
Solution type: VendorFix
Upgrade to Samba 4.6.8, 4.5.14 or 4.4.16

Affected Software/OS
Samba versions 4.1.0 to 4.6.7

Vulnerability Insight
A connection actually made use of the SMB3 encryption, any redirected connection would lose the requirement for encryption and also the requirement for signing.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Server 'SMB3' MitM Vulnerability (CVE-2017-12151)`
OID:1.3.6.1.4.1.25623.1.0.811906
Version used: `2025-09-17T05:39:26Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2017-12151
url: https://www.samba.org/samba/security/CVE-2017-12151.html
url: http://www.securityfocus.com/bid/100917
cert-bund: CB-K18/0478
cert-bund: CB-K17/2077
cert-bund: CB-K17/1876
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: CB-K17/1603
dfn-cert: DFN-CERT-2018-0513
dfn-cert: DFN-CERT-2017-2172
dfn-cert: DFN-CERT-2017-1953
dfn-cert: DFN-CERT-2017-1671
```

High (CVSS: 7.4)
NVT: Samba Server 'SMB 1/2/3' MitM Vulnerability (CVE-2017-12150)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to a MitM vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.4.16, or 4.5.14, or 4.6.8
Installation
path / port:       445/tcp
```

Impact

Successful exploitation will allow a remote attacker to read and/or alter the content of the connection.

Solution:

Solution type: VendorFix

Upgrade to Samba 4.6.8, 4.5.14 or 4.4.16

Affected Software/OS

Samba versions 3.0.25 to 4.6.7

Vulnerability Insight

The flaw exists due to there are several code paths where the code doesn't enforce SMB signing.

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.

Details: `Samba Server 'SMB 1/2/3' MitM Vulnerability (CVE-2017-12150)`

OID:1.3.6.1.4.1.25623.1.0.811907

Version used: `2025-09-17T05:39:26Z`

. . . continues on next page . . .

. . . continued from previous page . . .

Product Detection Result
Product: cpe:/a:samba:samba:4.5.9
Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
cve: CVE-2017-12150
url: https://www.samba.org/samba/security/CVE-2017-12150.html
url: http://www.securityfocus.com/bid/100918
cert-bund: CB-K18/0478
cert-bund: CB-K17/2077
cert-bund: CB-K17/1876
cert-bund: CB-K17/1603
dfn-cert: DFN-CERT-2018-0513
dfn-cert: DFN-CERT-2017-2172
dfn-cert: DFN-CERT-2017-1953
dfn-cert: DFN-CERT-2017-1671

High (CVSS: 7.1)
NVT: Samba Server 'SMB1' Memory Information Leak Vulnerability (CVE-2017-12163)

Product detection result
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)

Summary
Samba is prone to a memory information leak vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
Installed version: 4.5.9
Fixed version: 4.5.14
Installation
path / port: 445/tcp

Impact
Successful exploitation will allow a client with write access to a share can cause server memory contents to be written into a file or printer.

Solution:
Solution type: VendorFix
Upgrade to Samba 4.6.8, 4.5.14 and 4.4.16 or later.

. . . continues on next page . . .

. . . continued from previous page . . .

Affected Software/OS
Samba versions before 4.4.16, 4.5.0 before 4.5.14, and 4.6.0 before 4.6.8.

Vulnerability Insight
A server memory information leak bug over SMB1 if a client can write data to a share. Some SMB1 write requests were not correctly range checked to ensure the client had sent enough data to fulfill the write.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Server 'SMB1' Memory Information Leak Vulnerability (CVE-2017-12163)`
OID:1.3.6.1.4.1.25623.1.0.811905
Version used: `2025-09-17T05:39:26Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2017-12163
url: https://www.samba.org/samba/security/CVE-2017-12163.html
url: http://www.securityfocus.com/bid/100925
cert-bund: CB-K18/0478
cert-bund: CB-K17/2077
cert-bund: CB-K17/1876
cert-bund: CB-K17/1603
dfn-cert: DFN-CERT-2018-0513
dfn-cert: DFN-CERT-2017-2172
dfn-cert: DFN-CERT-2017-1953
dfn-cert: DFN-CERT-2017-1671
```

[return to 172.30.4.1]

2.1.3 Medium 445/tcp

Medium (CVSS: 6.8)
NVT: Samba Symlink Race Vulnerability (CVE-2021-20316)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
Samba is prone to a symlinc race vulnerability which can allow metadata read and modify outside of the exported share.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.15.0
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.15.0 or later.

Affected Software/OS
Samba prior to version 4.15.0.

Vulnerability Insight
A malicious client can use a symlink race to access or modify file or directory metadata information outside of the exported share. The user must have permissions to read or write the metadata on the accessed file or directory.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Symlink Race Vulnerability (CVE-2021-20316)`
OID:1.3.6.1.4.1.25623.1.0.147401
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2021-20316
url: https://www.samba.org/samba/history/samba-4.15.0.html
url: https://www.samba.org/samba/security/CVE-2021-20316.html
cert-bund: WID-SEC-2022-0465
cert-bund: CB-K22/0027
dfn-cert: DFN-CERT-2022-1032
dfn-cert: DFN-CERT-2022-0264
dfn-cert: DFN-CERT-2022-0242
```

Medium (CVSS: 6.8)
NVT: Samba 3.6.0 < 4.12.15, 4.13.0 < 4.13.8, 4.14.0 < 4.14.4 File Access Vulnerability

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to a unauthorized file access vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.12.15
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.12.15, 4.13.8, 4.14.4 or later.

Affected Software/OS
Samba version 3.6.0 and later.

Vulnerability Insight
The Samba smbd file server must map Windows group identities (SIDs) into unix group ids (gids). The code that performs this had a flaw that could allow it to read data beyond the end of the array in the case where a negative cache entry had been added to the mapping cache. This could cause the calling code to return those values into the process token that stores the group membership for a user.
Most commonly this flaw causes the calling code to crash, but it was found that an unprivileged user may be able to delete a file within a network share that they should have been disallowed access to.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 3.6.0 < 4.12.15, 4.13.0 < 4.13.8, 4.14.0 < 4.14.4 File Access Vulnerabili.`
`↪..`
OID:1.3.6.1.4.1.25623.1.0.145916
Version used: `2021-08-25T12:01:03Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`

. . . continues on next page . . .

. . . continued from previous page . . .

OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2021-20254
url: https://www.samba.org/samba/security/CVE-2021-20254.html
cert-bund: WID-SEC-2023-2980
cert-bund: WID-SEC-2023-0063
cert-bund: WID-SEC-2022-0530
cert-bund: CB-K21/0451
dfn-cert: DFN-CERT-2022-1469
dfn-cert: DFN-CERT-2022-0332
dfn-cert: DFN-CERT-2022-0074
dfn-cert: DFN-CERT-2021-2438
dfn-cert: DFN-CERT-2021-2072
dfn-cert: DFN-CERT-2021-1167
dfn-cert: DFN-CERT-2021-0929
dfn-cert: DFN-CERT-2021-0906
dfn-cert: DFN-CERT-2021-0902
```

Medium (CVSS: 6.6)
NVT: Samba Security Feature Bypass Vulnerability (CVE-2020-17049)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to a security feature bypass vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.13.13
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.13.13, 4.14.9, 4.15.1 or later.

Affected Software/OS

Samba versions prior to 4.13.13, 4.14.x prior to 4.14.9 and version 4.15.0.

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Insight
BUG 14642: Provide a fix for MS CVE-2020-17049 in Samba [SECURITY] 'Bronze bit' S4U2Proxy Constrained Delegation bypass in Samba with embedded Heimdal.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Security Feature Bypass Vulnerability (CVE-2020-17049)`
OID:1.3.6.1.4.1.25623.1.0.117760
Version used: `2024-01-03T05:05:19Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2020-17049
url: https://www.samba.org/samba/history/samba-4.13.13.html
url: https://www.samba.org/samba/history/samba-4.14.9.html
url: https://www.samba.org/samba/history/samba-4.15.1.html
url: https://bugzilla.samba.org/show_bug.cgi?id=14642
url: https://blog.netspi.com/cve-2020-17049-kerberos-bronze-bit-overview
url: https://blog.netspi.com/cve-2020-17049-kerberos-bronze-bit-theory
url: https://github.com/SecureAuthCorp/impacket/pull/1013
cert-bund: WID-SEC-2023-1542
cert-bund: WID-SEC-2022-2280
cert-bund: WID-SEC-2022-0432
cert-bund: WID-SEC-2022-0302
cert-bund: CB-K21/1126
cert-bund: CB-K20/1109
dfn-cert: DFN-CERT-2024-0078
dfn-cert: DFN-CERT-2023-1053
dfn-cert: DFN-CERT-2022-1686
dfn-cert: DFN-CERT-2022-0332
dfn-cert: DFN-CERT-2020-2464
```

Medium (CVSS: 6.5)
NVT: Samba DoS Vulnerability (CVE-2019-3824)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
Samba is prone to a denial of service (DoS) vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.10.0
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.10.0 or later.

Affected Software/OS
Samba versions 4.1.x through 4.9.x.

Vulnerability Insight
A flaw was found in the way an LDAP search expression could crash the shared LDAP server process of a samba AD DC. An authenticated user, having read permissions on the LDAP server, could use this flaw to cause denial of service.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba DoS Vulnerability (CVE-2019-3824)`
OID:1.3.6.1.4.1.25623.1.0.147117
Version used: `2021-11-08T14:03:29Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2019-3824
url: https://bugzilla.samba.org/show_bug.cgi?id=13773
cert-bund: CB-K19/0204
dfn-cert: DFN-CERT-2019-0410
```

Medium (CVSS: 6.5)
NVT: Samba File Truncation Vulnerability (CVE-2023-3347)

Product detection result

. . . continues on next page . . .

. . . continued from previous page . . .

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to a file truncation vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.17.12 / 4.18.8 / 4.19.1
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.17.12, 4.18.8, 4.19.1 or later.

Affected Software/OS
Samba versions prior to 4.17.12, 4.18.x prior to 4.18.8 and 4.19.0 only.

Vulnerability Insight
SMB client can truncate files to 0 bytes by opening files with OVERWRITE disposition when using the acl_xattr Samba VFS module with the smb.conf setting 'acl_xattr:ignore system acls = yes'.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba File Truncation Vulnerability (CVE-2023-3347)`
OID:1.3.6.1.4.1.25623.1.0.104957
Version used: `2023-11-16T05:05:14Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2023-4091
url: https://lists.samba.org/archive/samba-announce/2023/000651.html
url: https://www.samba.org/samba/security/CVE-2023-4091.html
cert-bund: WID-SEC-2023-2620
dfn-cert: DFN-CERT-2024-1065
dfn-cert: DFN-CERT-2024-0839
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2023-2700
dfn-cert: DFN-CERT-2023-2494
dfn-cert: DFN-CERT-2023-2462
dfn-cert: DFN-CERT-2023-2447
dfn-cert: DFN-CERT-2023-2443
```

Medium (CVSS: 6.5)
NVT: Samba DoS Vulnerability (CVE-2018-16841)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to a denial of service (DoS) vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.7.12
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.7.12, 4.8.7, 4.9.3 or later.

Affected Software/OS
Samba 4.3.0 and later.

Vulnerability Insight
A user with a valid certificate or smart card can crash the Samba AD DC's KDC.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba DoS Vulnerability (CVE-2018-16841)`
OID:1.3.6.1.4.1.25623.1.0.141734
Version used: `2022-08-31T10:10:28Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`

. . . continues on next page . . .

. . . continued from previous page . . .

OID: 1.3.6.1.4.1.25623.1.0.102011)

References
cve: CVE-2018-16841
url: https://www.samba.org/samba/security/CVE-2018-16841.html
cert-bund: CB-K18/1123
dfn-cert: DFN-CERT-2018-2539
dfn-cert: DFN-CERT-2018-2430
dfn-cert: DFN-CERT-2018-2429

Medium (CVSS: 6.5)
NVT: Samba < 4.14.8 DoS Vulnerability

Product detection result
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)

Summary
Samba is prone to a denial of service (DoS) vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
Installed version: 4.5.9
Fixed version: 4.14.8
Installation
path / port: 445/tcp

Solution:
Solution type: VendorFix
Update to version 4.14.8 or later.

Affected Software/OS
Samba prior to version 4.14.8.

Vulnerability Insight
An unuthenticated user can crash the AD DC KDC by omitting the server name in a TGS-REQ.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: Samba < 4.14.8 DoS Vulnerability
OID:1.3.6.1.4.1.25623.1.0.146864
Version used: 2021-10-21T08:03:33Z

. . . continues on next page . . .

. . . continued from previous page . . .

Product Detection Result
Product: cpe:/a:samba:samba:4.5.9
Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
cve: CVE-2021-3671
url: https://www.samba.org/samba/history/samba-4.14.8.html
cert-bund: WID-SEC-2022-2372
cert-bund: WID-SEC-2022-1714
cert-bund: CB-K21/1034
dfn-cert: DFN-CERT-2022-2612
dfn-cert: DFN-CERT-2022-2269
dfn-cert: DFN-CERT-2021-2539

Medium (CVSS: 6.5)
NVT: Samba 4.x Multiple DoS Vulnerabilities (CVE-2018-14629, CVE-2018-16851)

Product detection result
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)

Summary
Samba is prone to multiple denial of service (DoS) vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
Installed version: 4.5.9
Fixed version: 4.7.12
Installation
path / port: 445/tcp

Solution:
Solution type: VendorFix
Update to version 4.7.12, 4.8.7, 4.9.3 or later.

Affected Software/OS
Samba version 4.x.x.

Vulnerability Insight
Samba is prone to multiple vulnerabilities:

. . . continues on next page . . .

. . . continued from previous page . . .

- CVE-2018-14629: CNAME loops can cause DNS server crashes, and CNAMEs can be added by unprivileged users.
- CVE-2018-16851: A user able to read more than 256MB of LDAP entries can crash the Samba AD DC's LDAP server.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 4.x Multiple DoS Vulnerabilities (CVE-2018-14629, CVE-2018-16851)`
OID:1.3.6.1.4.1.25623.1.0.141732
Version used: `2023-11-03T16:10:08Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2018-14629
cve: CVE-2018-16851
url: https://www.samba.org/samba/security/CVE-2018-14629.html
url: https://www.samba.org/samba/security/CVE-2018-16851.html
cert-bund: CB-K18/1123
dfn-cert: DFN-CERT-2018-2558
dfn-cert: DFN-CERT-2018-2539
dfn-cert: DFN-CERT-2018-2430
dfn-cert: DFN-CERT-2018-2429
```

Medium (CVSS: 6.5)
NVT: Samba Multiple Use-after-free Vulnerabilities (CVE-2020-10730, CVE-2020-10760)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to two use-after-free vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 4.5.9
Fixed version:     4.10.17
Installation
path / port:       445/tcp
```

. . . continues on next page . . .

. . . continued from previous page . . .

Solution:
Solution type: VendorFix
Update to version 4.10.17, 4.11.11, 4.12.4 or later.

Affected Software/OS
All Samba versions since 4.5.0.

Vulnerability Insight
- A client combining the 'ASQ' and 'VLV' LDAP controls can cause a NULL pointer de-reference and further combinations with the LDAP paged_results feature can give a use-after-free in Samba's AD DC LDAP server. (CVE-2020-10730)
- The use of the paged_results or VLV controls against the Global Catalog LDAP server on the AD DC will cause a use-after-free. (CVE-2020-10760)

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Multiple Use-after-free Vulnerabilities (CVE-2020-10730, CVE-2020-10760)`
OID:1.3.6.1.4.1.25623.1.0.108815
Version used: `2021-08-11T08:56:08Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2020-10730`
`cve: CVE-2020-10760`
`url: https://www.samba.org/samba/security/CVE-2020-10730.html`
`url: https://www.samba.org/samba/security/CVE-2020-10760.html`
`cert-bund: CB-K20/0657`
`dfn-cert: DFN-CERT-2021-0807`
`dfn-cert: DFN-CERT-2021-0674`
`dfn-cert: DFN-CERT-2020-2567`
`dfn-cert: DFN-CERT-2020-2026`
`dfn-cert: DFN-CERT-2020-1614`
`dfn-cert: DFN-CERT-2020-1578`
`dfn-cert: DFN-CERT-2020-1417`

Medium (CVSS: 6.5)
NVT: Samba Multiple Vulnerabilities (Mar 2023)

Product detection result

. . . continues on next page . . .

. . . continued from previous page . . .

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.16.10 / 4.17.7 / 4.18.1
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.16.10, 4.17.7, 4.18.1 or later.

Affected Software/OS
All versions of Samba since 4.0.

Vulnerability Insight
The following flaws exist:
- CVE-2023-0614: Access controlled AD LDAP attributes can be discovered
- CVE-2023-0922: Samba AD DC admin tool samba-tool sends passwords in cleartext

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Multiple Vulnerabilities (Mar 2023)`
OID:1.3.6.1.4.1.25623.1.0.104663
Version used: `2023-10-13T05:06:10Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2023-0614
cve: CVE-2023-0922
url: https://www.samba.org/samba/security/CVE-2023-0614.html
url: https://www.samba.org/samba/security/CVE-2023-0922.html
cert-bund: WID-SEC-2023-0796
dfn-cert: DFN-CERT-2023-0858
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2023-0857
dfn-cert: DFN-CERT-2023-0713
dfn-cert: DFN-CERT-2023-0710
dfn-cert: DFN-CERT-2023-0707
```

Medium (CVSS: 6.5)
NVT: Samba 'AD LDAP' Information Disclosure Vulnerability (Aug 2018)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to an information disclosure vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.6.16 or apply patch
Installation
path / port:       445/tcp
```

Impact
Successful exploitation will allow an attacker to gain access to confidential attribute values.

Solution:
Solution type: VendorFix
Update to version 4.8.4 or 4.7.9 or 4.6.16 or later. Please see the references for more information.

Affected Software/OS
All versions of Samba from 4.0.0 onwards.

Vulnerability Insight
The flaw exists due to a missing access control checks.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 'AD LDAP' Information Disclosure Vulnerability (Aug 2018)`
OID:1.3.6.1.4.1.25623.1.0.813784
Version used: `2021-09-29T12:07:39Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`

. . . continues on next page . . .

. . . continued from previous page . . .

Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2018-10919
url: https://www.samba.org/samba/security/CVE-2018-10919.html
url: https://www.samba.org/samba/history/samba-4.8.4.html
url: https://www.samba.org/samba/history/samba-4.7.9.html
url: https://www.samba.org/samba/history/samba-4.6.16.html
cert-bund: CB-K18/0866
dfn-cert: DFN-CERT-2019-0420
dfn-cert: DFN-CERT-2018-2098
dfn-cert: DFN-CERT-2018-1806
dfn-cert: DFN-CERT-2018-1608
dfn-cert: DFN-CERT-2018-1598
dfn-cert: DFN-CERT-2018-1594
```

Medium (CVSS: 6.5)
NVT: Samba 4.0.0 < 4.17.12, 4.18.0 < 4.18.8, 4.19.0 Multiple Vulnerabilities

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.17.12 / 4.18.8 / 4.19.1
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.17.12, 4.18.8, 4.19.1 or later.

Affected Software/OS

All versions of Samba since 4.0.0.

Vulnerability Insight

. . . continues on next page . . .

. . . continued from previous page . . .

The following flaws exist:
- CVE-2023-4154: Samba AD DC password exposure to privileged users and RODCs
- CVE-2023-42669: 'rpcecho' development server allows Denial of Service via sleep() call on AD DC

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 4.0.0 < 4.17.12, 4.18.0 < 4.18.8, 4.19.0 Multiple Vulnerabilities`
OID:1.3.6.1.4.1.25623.1.0.104958
Version used: `2023-11-16T05:05:14Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2023-4154
cve: CVE-2023-42669
url: https://lists.samba.org/archive/samba-announce/2023/000651.html
url: https://www.samba.org/samba/security/CVE-2023-4154.html
url: https://www.samba.org/samba/security/CVE-2023-42669.html
cert-bund: WID-SEC-2024-0523
cert-bund: WID-SEC-2023-2620
dfn-cert: DFN-CERT-2023-2700
dfn-cert: DFN-CERT-2023-2494
dfn-cert: DFN-CERT-2023-2447
dfn-cert: DFN-CERT-2023-2443
```

Medium (CVSS: 6.5)
NVT: Samba Security Vulnerability (CVE-2019-10218)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Malicious servers can cause Samba client code to return filenames containing path separators to calling code.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 4.5.9
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
Fixed version:     4.9.15
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.9.15, 4.10.10, 4.11.2 or later.

Affected Software/OS
Samba versions prior to 4.9.15, 4.10.x through 4.10.9 and 4.11.x through 4.11.1.
Note: This flaw affects the client code (libsmbclient) of the remote Samba server installation.

Vulnerability Insight
Samba client code (libsmbclient) returns server-supplied filenames to calling code without checking for pathname separators (such as '/' or '../') in the server returned names.
A malicious server can craft a pathname containing separators and return this to client code, causing the client to use this access local pathnames for reading or writing instead of SMB network pathnames.
This access is done using the local privileges of the client.
This attack can be achieved using any of SMB1/2/3 as it is not reliant on any specific SMB protocol version.
Specifically, samba client tools like smbget and smbclient's mget use the server supplied 'final' name component as a local name when obtaining multiple files. While the design of these tools is that server can always choose the file names, this vulnerability is that it allows a remote server to create local files outside the current working directory.
Users of the libsmbclient library external to Samba may also be vulnerable if they use server returned filenames without adequate checking and pass them to functions that do local filesystem access.
Note that the Gnome GVFS client library is not believed to be vulnerable, as it always passes server-returned pathnames back to the SMB share they were returned from. Such malformed pathnames are then rejected by the server.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Security Vulnerability (CVE-2019-10218)`
OID:1.3.6.1.4.1.25623.1.0.117772
Version used: `2021-12-03T14:28:28Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2019-10218`

. . . continues on next page . . .

. . . continued from previous page . . .

```
url: https://www.samba.org/samba/security/CVE-2019-10218.html
cert-bund: WID-SEC-2023-2366
cert-bund: CB-K19/0945
dfn-cert: DFN-CERT-2023-2166
dfn-cert: DFN-CERT-2021-1167
dfn-cert: DFN-CERT-2020-2026
dfn-cert: DFN-CERT-2020-1078
dfn-cert: DFN-CERT-2020-0891
dfn-cert: DFN-CERT-2020-0657
dfn-cert: DFN-CERT-2020-0600
dfn-cert: DFN-CERT-2020-0375
dfn-cert: DFN-CERT-2019-2244
dfn-cert: DFN-CERT-2019-2240
```

Medium (CVSS: 6.5)
NVT: Samba Multiple Vulnerabilities (CVE-2019-14902, CVE-2019-14907)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.9.18
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.9.18, 4.10.12, 4.11.5 or later.

Affected Software/OS

Samba version 4.0 and later.

Vulnerability Insight

Samba is prone to multiple vulnerabilities:

- Removal of the right to create or modify a subtree would not automatically be taken away on all domain controllers (CVE-2019-14902)

- Crash after failed character conversion at log level 3 or above (CVE-2019-14907)

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Multiple Vulnerabilities (CVE-2019-14902, CVE-2019-14907)`
OID:1.3.6.1.4.1.25623.1.0.143374
Version used: `2023-10-20T16:09:12Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2019-14902
cve: CVE-2019-14907
url: https://www.samba.org/samba/security/CVE-2019-14902.html
url: https://www.samba.org/samba/security/CVE-2019-14907.html
cert-bund: WID-SEC-2023-2365
cert-bund: CB-K20/1030
cert-bund: CB-K20/0064
dfn-cert: DFN-CERT-2023-2166
dfn-cert: DFN-CERT-2021-1167
dfn-cert: DFN-CERT-2020-2026
dfn-cert: DFN-CERT-2020-1078
dfn-cert: DFN-CERT-2020-0891
dfn-cert: DFN-CERT-2020-0600
dfn-cert: DFN-CERT-2020-0167
dfn-cert: DFN-CERT-2020-0141
dfn-cert: DFN-CERT-2020-0138
```

Medium (CVSS: 6.5)
NVT: Samba DoS Vulnerability (CVE-2020-14383)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to a denial of service vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 4.5.9
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
Fixed version:      4.11.15
Installation
path / port:        445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.11.15, 4.12.9, 4.13.1 or later.

Affected Software/OS
All versions of Samba since version 4.0.0.

Vulnerability Insight
An authenticated non-admin user can crash the DNS server by adding invalid records.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba DoS Vulnerability (CVE-2020-14383)`
OID:1.3.6.1.4.1.25623.1.0.144977
Version used: `2021-08-11T08:56:08Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2020-14383`
`url: https://www.samba.org/samba/security/CVE-2020-14383.html`
`cert-bund: WID-SEC-2023-0174`
`cert-bund: CB-K20/1051`
`dfn-cert: DFN-CERT-2024-1065`
`dfn-cert: DFN-CERT-2021-0929`
`dfn-cert: DFN-CERT-2020-2567`
`dfn-cert: DFN-CERT-2020-2346`

Medium (CVSS: 6.5)
NVT: Samba Unspecified Vulnerability (CVE-2021-3670)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary

. . . continues on next page . . .

. . . continued from previous page . . .

Samba is prone to an unspecified vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.14.13
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.14.13, 4.15.6 or later.

Affected Software/OS
Samba version 4.1.0 through 4.14.12 and 4.15.x through 4.15.5.

Vulnerability Insight
LDAP search filters can be very complex, search filters are not limited to indexed attributes and they can also include complex extended match rules like LDAP_MATCHING_RULE_IN_CHAIN.
The LDAP Policy setting 'lDAPAdminLimits: MaxQueryDuration=120' (by default) should have provided a generous upper bound, however the policy was previously not considered in setting the timeout.
Additionally, no interruption points were set in the filter handling to check if the operation was over-time.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Unspecified Vulnerability (CVE-2021-3670)`
OID:1.3.6.1.4.1.25623.1.0.113941
Version used: `2024-06-26T05:05:39Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2021-3670
url: https://bugzilla.samba.org/show_bug.cgi?id=14694
url: https://bugzilla.redhat.com/show_bug.cgi?id=2077533
cert-bund: WID-SEC-2022-0588
cert-bund: CB-K22/0490
dfn-cert: DFN-CERT-2022-1025
```

Medium (CVSS: 6.5)
NVT: Samba 4.0 Buffer Overflow Vulnerability (CVE-2022-3437)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to a buffer overflow vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 4.5.9
Fixed version:     4.15.11
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.15.11, 4.16.6, 4.17.2 or later.

Affected Software/OS
Samba versions starting from 4.0 and prior to 4.15.11, 4.16.x prior to 4.16.6 and 4.17.x prior to 4.17.2.

Vulnerability Insight
There is a limited write heap buffer overflow in the GSSAPI unwrap_des() and unwrap_des3() routines of Heimdal (included in Samba).

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 4.0 Buffer Overflow Vulnerability (CVE-2022-3437)`
OID:1.3.6.1.4.1.25623.1.0.126187
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2022-3437
url: https://www.samba.org/samba/history/samba-4.17.2.html
url: https://www.samba.org/samba/history/samba-4.16.6.html
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
url: https://www.samba.org/samba/history/samba-4.15.11.html
url: https://www.samba.org/samba/security/CVE-2022-3437.html
cert-bund: WID-SEC-2022-2372
cert-bund: WID-SEC-2022-1847
dfn-cert: DFN-CERT-2025-1637
dfn-cert: DFN-CERT-2024-1065
dfn-cert: DFN-CERT-2024-0839
dfn-cert: DFN-CERT-2023-0199
dfn-cert: DFN-CERT-2023-0089
dfn-cert: DFN-CERT-2022-2804
dfn-cert: DFN-CERT-2022-2612
dfn-cert: DFN-CERT-2022-2603
dfn-cert: DFN-CERT-2022-2374
dfn-cert: DFN-CERT-2022-2364
```

Medium (CVSS: 5.9)
NVT: Samba 4.1 < 4.17.1 Improper Authentication (CVE-2021-20251)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to an improper authentication vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.17.1
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.17.1 or later.

Affected Software/OS

Samba version 4.1 through 4.17.1.

Vulnerability Insight

By making bad password count handling atomic, we ensure only one failed authorisation attempt can get through at a time, and refuse excess login attempts made to the same server.

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 4.1 < 4.17.1 Improper Authentication (CVE-2021-20251)`
OID:1.3.6.1.4.1.25623.1.0.126184
Version used: `2023-10-19T05:05:21Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2021-20251
url: https://www.samba.org/samba/history/samba-4.17.1.html
url: https://bugzilla.samba.org/show_bug.cgi?id=14611
cert-bund: WID-SEC-2022-1799
dfn-cert: DFN-CERT-2023-0201
dfn-cert: DFN-CERT-2023-0199
dfn-cert: DFN-CERT-2023-0176
dfn-cert: DFN-CERT-2023-0153
```

Medium (CVSS: 5.5)
NVT: Samba ZeroLogon Vulnerability (CVE-2020-1472)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to an unauthenticated domain takeover vulnerability via netlogon (ZeroLogon).

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 4.5.9
Fixed version:     4.10.18
Installation
path / port:       445/tcp
```

Impact
An unauthenticated attacker on the network can gain administrator access by exploiting a netlogon protocol flaw.

Solution:

. . . continues on next page . . .

. . . continued from previous page . . .

Solution type: VendorFix
Update to version 4.10.18, 4.11.13, 4.12.7 or later.

Affected Software/OS
Samba version 4.0 and later.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba ZeroLogon Vulnerability (CVE-2020-1472)`
OID:1.3.6.1.4.1.25623.1.0.144680
Version used: `2024-01-05T16:09:35Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2020-1472
cisa: Known Exploited Vulnerability (KEV) catalog
url: https://www.cisa.gov/known-exploited-vulnerabilities-catalog
url: https://www.samba.org/samba/security/CVE-2020-1472.html
url: https://www.kb.cert.org/vuls/id/490028
cert-bund: CB-K21/0411
cert-bund: CB-K20/0816
dfn-cert: DFN-CERT-2021-2072
dfn-cert: DFN-CERT-2021-1504
dfn-cert: DFN-CERT-2021-0827
dfn-cert: DFN-CERT-2021-0444
dfn-cert: DFN-CERT-2020-2749
dfn-cert: DFN-CERT-2020-2567
dfn-cert: DFN-CERT-2020-2024
dfn-cert: DFN-CERT-2020-1768
```

Medium (CVSS: 5.5)
NVT: Samba 3.6.0 <= 4.13.1 DoS Vulnerability (CVE-2020-14323)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to a denial of service vulnerability.

. . . continues on next page . . .

. . . continued from previous page . . .

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.11.15
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.11.15, 4.12.9, 4.13.1 or later.

Affected Software/OS
All versions of Samba since version 3.6.0.

Vulnerability Insight
With a specially crafted winbind request sent over the non-privileged winbind pipe winbind can be made to dereference a NULL pointer.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba 3.6.0 <= 4.13.1 DoS Vulnerability (CVE-2020-14323)`
OID:1.3.6.1.4.1.25623.1.0.150737
Version used: `2021-09-29T03:57:12Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2020-14323
url: https://www.samba.org/samba/security/CVE-2020-14323.html
cert-bund: WID-SEC-2023-0174
cert-bund: CB-K22/0130
cert-bund: CB-K20/1051
dfn-cert: DFN-CERT-2024-1065
dfn-cert: DFN-CERT-2023-0153
dfn-cert: DFN-CERT-2022-0224
dfn-cert: DFN-CERT-2021-2072
dfn-cert: DFN-CERT-2021-1504
dfn-cert: DFN-CERT-2021-0929
dfn-cert: DFN-CERT-2021-0444
dfn-cert: DFN-CERT-2020-2749
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2020-2567
dfn-cert: DFN-CERT-2020-2346
```

Medium (CVSS: 5.4)
NVT: Samba AD DC Check Password Script Weakness (CVE-2019-14833)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

When the password contains multi-byte (non-ASCII) characters, the check password script of Samba AD DC does not receive the full password string.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.9.15
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.11.2, 4.10.10, 4.9.15 or later.

Affected Software/OS

Samba 4.5.0 and later

Vulnerability Insight

Since Samba Version 4.5.0 a Samba AD DC can use a custom command to verify the password complexity. The command can be specified with the 'check password script' smb.conf parameter. This command is called when Samba handles a user password change or a new user password is set. The script receives the new cleartext password string in order to run custom password complexity checks like dictionary checks to avoid weak user passwords.

When the password contains multi-byte (non-ASCII) characters, the check password script does not receive the full password string.

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.

Details: `Samba AD DC Check Password Script Weakness (CVE-2019-14833)`

OID:1.3.6.1.4.1.25623.1.0.108693

Version used: `2025-09-16T05:38:45Z`

. . . continues on next page . . .

. . . continued from previous page . . .

Product Detection Result
Product: cpe:/a:samba:samba:4.5.9
Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
cve: CVE-2019-14833
url: https://www.samba.org/samba/security/CVE-2019-14833.html
cert-bund: WID-SEC-2023-2366
cert-bund: CB-K19/0945
dfn-cert: DFN-CERT-2023-2166
dfn-cert: DFN-CERT-2021-1167
dfn-cert: DFN-CERT-2020-2026
dfn-cert: DFN-CERT-2020-0375
dfn-cert: DFN-CERT-2019-2240

Medium (CVSS: 5.4)
NVT: Samba Multiple Vulnerabilities (CVE-2019-14861, CVE-2019-14870)

Product detection result
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)

Summary
Samba is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
Installed version: 4.5.9
Fixed version: 4.9.17
Installation
path / port: 445/tcp

Solution:
Solution type: VendorFix
Update to version 4.9.17, 4.10.11, 4.11.3 or later.

Affected Software/OS
Samba versions 4.x.

Vulnerability Insight
Samba is prone to multiple vulnerabilities:

. . . continues on next page . . .

. . . continued from previous page . . .

- Samba AD DC zone-named record Denial of Service in DNS management server (CVE-2019-14861)
- DelegationNotAllowed not being enforced in protocol transition on Samba AD DC (CVE-2019-14870)

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Multiple Vulnerabilities (CVE-2019-14861, CVE-2019-14870)`
OID:1.3.6.1.4.1.25623.1.0.143243
Version used: `2021-09-06T11:01:35Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2019-14861
cve: CVE-2019-14870
url: https://www.samba.org/samba/security/CVE-2019-14861.html
url: https://www.samba.org/samba/security/CVE-2019-14870.html
cert-bund: WID-SEC-2022-2051
cert-bund: CB-K19/1048
dfn-cert: DFN-CERT-2022-2612
dfn-cert: DFN-CERT-2022-2603
dfn-cert: DFN-CERT-2021-1167
dfn-cert: DFN-CERT-2020-2026
dfn-cert: DFN-CERT-2019-2593
```

Medium (CVSS: 5.4)
NVT: Samba Path/Symlink Traversal Vulnerability (CVE-2019-3880)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary
Samba is prone to a path/symlink traversal vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 4.5.9
Fixed version:     4.8.11
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
Installation
path / port:        445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.8.11, 4.9.6, 4.10.2 or later.

Affected Software/OS
Samba 3.2.0 and later.

Vulnerability Insight
A flaw was found in the way samba implemented an RPC endpoint emulating the Windows registry service API. An unprivileged attacker could use this flaw to create a new registry hive file anywhere they have unix permissions which could lead to creation of a new file in the Samba share.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Path/Symlink Traversal Vulnerability (CVE-2019-3880)`
OID:1.3.6.1.4.1.25623.1.0.142391
Version used: `2025-09-16T05:38:45Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2019-3880
url: https://www.samba.org/samba/security/CVE-2019-3880.html
cert-bund: CB-K19/0277
dfn-cert: DFN-CERT-2019-0924
dfn-cert: DFN-CERT-2019-0836
dfn-cert: DFN-CERT-2019-0726
dfn-cert: DFN-CERT-2019-0700
```

Medium (CVSS: 4.9)
NVT: Samba DoS Vulnerability (CVE-2019-14847)

Product detection result
```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
Samba is prone to a denial of service vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.9.15
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.9.15, 4.10.10 or later.

Affected Software/OS
Samba 4.0.0 until Samba 4.10.9.
Samba 4.11 is not affected as the issue was fixed as a result of Coverity static analysis, before the potential for denial of service became apparent.

Vulnerability Insight
Since Samba 4.0.0 Samba has implemented, in the AD DC, the 'dirsync' LDAP control specified in MS-ADTS '3.1.1.3.4.1.3 LDAP_SERVER_DIRSYNC_OID'.
However, when combined with the ranged results feature specified in MS-ADTS '3.1.1.3.1.3.3 Range Retrieval of Attribute Values' a NULL pointer is can be de-referenced.
This is a Denial of Service only, no further escalation of privilege is associated with this issue.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba DoS Vulnerability (CVE-2019-14847)`
OID:1.3.6.1.4.1.25623.1.0.108694
Version used: `2025-09-16T05:38:45Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2019-14847
url: https://www.samba.org/samba/security/CVE-2019-14847.html
cert-bund: WID-SEC-2023-2366
cert-bund: CB-K19/0945
dfn-cert: DFN-CERT-2023-2166
dfn-cert: DFN-CERT-2021-1167
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2020-2026
dfn-cert: DFN-CERT-2020-0375
dfn-cert: DFN-CERT-2019-2240
```

Medium (CVSS: 4.3)
NVT: Samba Memory Disclosure Vulnerability (CVE-2025-9640)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to an uninitialized memory disclosure vulnerability via vfs_streams_xattr.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.21.9
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.21.9, 4.22.5, 4.23.2 or later.

Affected Software/OS

Samba version 3.2 prior to 4.21.9, 4.22.x prior to 4.22.5 and 4.23.x prior to 4.23.2.

Vulnerability Insight

An authenticated user can read an unlimited number of samples of discarded heap memory, due to a failure to initialise memory in streams_xattr_pwrite() in the vfs_streams_xattr file server module.

This is achieved by issuing write requests that creates holes in the file.

Samba erases known secrets before freeing the associated memory, which somewhat mitigates the data leak.

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.

Details: `Samba Memory Disclosure Vulnerability (CVE-2025-9640)`

OID:1.3.6.1.4.1.25623.1.0.155662

Version used: `2025-10-17T05:39:07Z`

Product Detection Result

. . . continues on next page . . .

. . . continued from previous page . . .

Product: cpe:/a:samba:samba:4.5.9
Method: SMB NativeLanMan
OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2025-9640
url: https://www.samba.org/samba/security/CVE-2025-9640.html
url: https://www.samba.org/samba/history/samba-4.21.9.html
url: https://www.samba.org/samba/history/samba-4.22.5.html
url: https://www.samba.org/samba/history/samba-4.23.2.html
url: https://lists.samba.org/archive/samba-announce/2025/000704.html
cert-bund: WID-SEC-2025-2322
dfn-cert: DFN-CERT-2025-3326
dfn-cert: DFN-CERT-2025-2874
```

Medium (CVSS: 4.3)
NVT: Samba Information Leak Vulnerability (CVE-2018-14628)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to an information leak vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.18.9
Installation
path / port:       445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.18.9, 4.19.3 or later.

Affected Software/OS

Samba versions from 4.0.0 onwards.

Vulnerability Insight

Samba is vulnerable to an information leak (compared with the established behaviour of Microsoft's Active Directory) when Samba is an Active Directory Domain Controller.

. . . continues on next page . . .

. . . continued from previous page . . .

Missing access control checks on the LDAP_SERVER_SHOW_DELETED_OID control in the DSDB database layer cause the LDAP server to disclose, to authenticated but not privileged users, the names and preserved attributes of deleted objects. (Microsoft AD simply does not return these objects on a search).
No information that was hidden before the deletion is visible, but in Microsoft Active Directory the whole object is also not visible without administrative rights, whereas Samba allows read of limited set of attributes that are preserved after delete.
There is no further vulnerability associated with this error, merely an information disclosure.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Information Leak Vulnerability (CVE-2018-14628)`
OID:1.3.6.1.4.1.25623.1.0.104503
Version used: `2023-11-30T05:06:26Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2018-14628`
`url: https://www.samba.org/samba/history/samba-4.19.3.html`
`url: https://www.samba.org/samba/history/samba-4.18.9.html`
`url: https://www.samba.org/samba/security/CVE-2018-14628.html`
`url: https://bugzilla.samba.org/show_bug.cgi?id=13595`
`url: https://bugzilla.redhat.com/show_bug.cgi?id=1625445`
`cert-bund: WID-SEC-2023-3012`
`dfn-cert: DFN-CERT-2023-2993`

Medium (CVSS: 4.3)
NVT: Samba Information Disclosure Vulnerability (CVE-2021-44141)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to an information disclosure vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
`Installed version: 4.5.9`

. . . continues on next page . . .

. . . continued from previous page . . .

```
Fixed version:      4.15.5
Installation
path / port:        445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.15.5 or later.

Affected Software/OS
Samba versions prior to 4.15.5.

Vulnerability Insight
Samba is vulnerable to a malicious client using a server symlink to determine if a file or directory exists in an area of the server file system not exported under the share definition. SMB1 with unix extensions has to be enabled in order for this attack to succeed.
Clients that have write access to the exported part of the file system under a share via SMB1 unix extensions or via NFS can create symlinks that point to arbitrary files or directories on the server filesystem.
Clients can then use SMB1 unix extension information queries to determine if the target of the symlink exists or not by examining error codes returned from the smbd server. There is no ability to access these files or directories, only to determine if they exist or not.
If SMB1 is turned off and only SMB2 is used, or unix extensions are not enabled then there is no way to discover if a symlink points to a valid target or not via SMB2. For this reason, even if symlinks are created via NFS, if the Samba server does not allow SMB1 with unix extensions there is no way to exploit this bug.
Finding out what files or directories exist on a file server can help attackers guess system user names or the exact operating system release and applications running on the server hosting Samba which may help mount further attacks.
SMB1 has been disabled on Samba since version 4.11.0 and onwards.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Information Disclosure Vulnerability (CVE-2021-44141)`
OID:1.3.6.1.4.1.25623.1.0.147555
Version used: `2022-02-25T03:03:32Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
`cve: CVE-2021-44141`
`url: https://www.samba.org/samba/security/CVE-2021-44141.html`
`cert-bund: WID-SEC-2022-0466`

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: CB-K22/0128
dfn-cert: DFN-CERT-2022-1032
dfn-cert: DFN-CERT-2022-0264
dfn-cert: DFN-CERT-2022-0242
dfn-cert: DFN-CERT-2022-0228
```

Medium (CVSS: 4.3)
NVT: Samba Information Disclosure Vulnerability (CVE-2020-14318)

Product detection result

```
cpe:/a:samba:samba:4.5.9
Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)
```

Summary

Samba is prone to an information disclosure vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 4.5.9
Fixed version:     4.11.15
Installation
path / port:       445/tcp
```

Solution:

Solution type: VendorFix

Update to version 4.11.15, 4.12.9, 4.13.1 or later.

Affected Software/OS

All versions of Samba since version 3.6.0.

Vulnerability Insight

Systems where Windows ACL permissions are more restrictive than native filesystem permissions can be made to leak file name information to unprivileged accounts.

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.

Details: `Samba Information Disclosure Vulnerability (CVE-2020-14318)`

OID:1.3.6.1.4.1.25623.1.0.144983

Version used: `2021-08-11T08:56:08Z`

Product Detection Result

Product: `cpe:/a:samba:samba:4.5.9`

Method: `SMB NativeLanMan`

. . . continues on next page . . .

. . . continued from previous page . . .

OID: 1.3.6.1.4.1.25623.1.0.102011)

References

```
cve: CVE-2020-14318
url: https://www.samba.org/samba/security/CVE-2020-14318.html
cert-bund: WID-SEC-2023-0174
cert-bund: CB-K20/1051
dfn-cert: DFN-CERT-2024-1065
dfn-cert: DFN-CERT-2021-2072
dfn-cert: DFN-CERT-2021-1504
dfn-cert: DFN-CERT-2021-0929
dfn-cert: DFN-CERT-2021-0444
dfn-cert: DFN-CERT-2020-2749
dfn-cert: DFN-CERT-2020-2567
dfn-cert: DFN-CERT-2020-2346
```

[return to 172.30.4.1]

2.1.4 Low general/tcp

Low (CVSS: 2.6)
NVT: TCP Timestamps Information Disclosure

Summary
The remote host implements TCP timestamps and therefore allows to compute the uptime.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
It was detected that the host implements RFC1323/RFC7323.
The following timestamps were retrieved with a delay of 1 seconds in-between:
Packet 1: 3804263481
Packet 2: 3804264626
```

Impact
A side effect of this feature is that the uptime of the remote host can sometimes be computed.

Solution:
Solution type: Mitigation
To disable TCP timestamps on linux add the line 'net.ipv4.tcp_timestamps = 0' to /etc/sysctl.conf. Execute 'sysctl -p' to apply the settings at runtime.
To disable TCP timestamps on Windows execute 'netsh int tcp set global timestamps=disabled' Starting with Windows Server 2008 and Vista, the timestamp can not be completely disabled.

. . . continues on next page . . .

. . . continued from previous page . . .

The default behavior of the TCP/IP stack on this Systems is to not use the Timestamp options when initiating TCP connections, but use them if the TCP peer that is initiating communication includes them in their synchronize (SYN) segment.
See the references for more information.

Affected Software/OS
TCP implementations that implement RFC1323/RFC7323.

Vulnerability Insight
The remote host implements TCP timestamps, as defined by RFC1323/RFC7323.

Vulnerability Detection Method
Special IP packets are forged and sent with a little delay in between to the target IP. The responses are searched for a timestamps. If found, the timestamps are reported.
Details: `TCP Timestamps Information Disclosure`
OID:1.3.6.1.4.1.25623.1.0.80091
Version used: `2023-12-15T16:10:08Z`

References
`url: https://datatracker.ietf.org/doc/html/rfc1323`
`url: https://datatracker.ietf.org/doc/html/rfc7323`
`url: https://web.archive.org/web/20151213072445/http://www.microsoft.com/en-us/d`
`↪ownload/details.aspx?id=9152`
`url: https://www.fortiguard.com/psirt/FG-IR-16-090`

[return to 172.30.4.1]

2.1.5 Low 445/tcp

Low (CVSS: 2.5)
NVT: Samba Share Escape Vulnerability (CVE-2021-43566)

Product detection result
`cpe:/a:samba:samba:4.5.9`
`Detected by SMB NativeLanMan (OID: 1.3.6.1.4.1.25623.1.0.102011)`

Summary
Samba is prone to a share escape vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
`Installed version: 4.5.9`

. . . continues on next page . . .

. . . continued from previous page . . .

```
Fixed version:      4.13.16
Installation
path / port:        445/tcp
```

Solution:
Solution type: VendorFix
Update to version 4.13.16 or later.

Affected Software/OS
Samba versions prior to 4.13.16.

Vulnerability Insight
Samba is vulnerable to a malicious client using an SMB1 or NFS symlink race to allow a directory to be created in an area of the server file system not exported under the share definition. Note that SMB1 has to be enabled, or the share also available via NFS in order for this attack to succeed.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `Samba Share Escape Vulnerability (CVE-2021-43566)`
OID:1.3.6.1.4.1.25623.1.0.117876
Version used: `2022-01-24T03:04:40Z`

Product Detection Result
Product: `cpe:/a:samba:samba:4.5.9`
Method: `SMB NativeLanMan`
OID: 1.3.6.1.4.1.25623.1.0.102011)

References
```
cve: CVE-2021-43566
url: https://www.samba.org/samba/history/samba-4.13.16.html
url: https://www.samba.org/samba/security/CVE-2021-43566.html
cert-bund: WID-SEC-2023-2979
cert-bund: WID-SEC-2022-1335
cert-bund: WID-SEC-2022-1228
cert-bund: WID-SEC-2022-0432
cert-bund: WID-SEC-2022-0302
cert-bund: CB-K22/0016
dfn-cert: DFN-CERT-2022-0865
dfn-cert: DFN-CERT-2022-0264
dfn-cert: DFN-CERT-2022-0242
dfn-cert: DFN-CERT-2022-0239
dfn-cert: DFN-CERT-2022-0035
```

[return to 172.30.4.1]

2.1.6 Low general/icmp

Low (CVSS: 2.1)
NVT: ICMP Timestamp Reply Information Disclosure

Summary
The remote host responded to an ICMP timestamp request.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
The following response / ICMP packet has been received:
- ICMP Type: 14
- ICMP Code: 0
```

Impact
This information could theoretically be used to exploit weak time-based random number generators in other services.

Solution:
Solution type: Mitigation
Various mitigations are possible:
- Disable the support for ICMP timestamp on the remote host completely
- Protect the remote host by a firewall, and block ICMP packets passing through the firewall in either direction (either completely or only for untrusted networks)

Vulnerability Insight
The Timestamp Reply is an ICMP message which replies to a Timestamp message. It consists of the originating timestamp sent by the sender of the Timestamp as well as a receive timestamp and a transmit timestamp.

Vulnerability Detection Method
Sends an ICMP Timestamp (Type 13) request and checks if a Timestamp Reply (Type 14) is received.
Details: `ICMP Timestamp Reply Information Disclosure`
OID:1.3.6.1.4.1.25623.1.0.103190
Version used: `2025-01-21T05:37:33Z`

References

```
cve: CVE-1999-0524
url: https://datatracker.ietf.org/doc/html/rfc792
url: https://datatracker.ietf.org/doc/html/rfc2780
cert-bund: CB-K15/1514
cert-bund: CB-K14/0632
dfn-cert: DFN-CERT-2014-0658
```

[return to 172.30.4.1]

2.1.7 Log general/tcp

Log (CVSS: 0.0)
NVT: Hostname Determination Reporting

Summary
The script reports information on how the hostname of the target was determined.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
```
Hostname determination for IP 172.30.4.1:
Hostname|Source
sambacry.trabalho_vulnnet|Reverse-DNS
```

Solution:

Log Method
Details: `Hostname Determination Reporting`
OID:1.3.6.1.4.1.25623.1.0.108449
Version used: `2022-07-27T10:11:28Z`

Log (CVSS: 0.0)
NVT: Traceroute

Summary
Collect information about the network route and network distance between the scanner host and the target host.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
```
Network route from scanner (172.30.0.2) to target (172.30.4.1):
172.30.0.2
172.30.4.1
Network distance between scanner and target: 2
```

Solution:

Vulnerability Insight
For internal networks, the distances are usually small, often less than 4 hosts between scanner and target. For public targets the distance is greater and might be 10 hosts or more.

Log Method

. . . continues on next page . . .

. . . continued from previous page . . .

A combination of the protocols ICMP and TCP is used to determine the route. This method is applicable for IPv4 only and it is also known as 'traceroute'.
Details: `Traceroute`
OID:1.3.6.1.4.1.25623.1.0.51662
Version used: `2022-10-17T11:13:19Z`

Log (CVSS: 0.0)
NVT: OS Detection Consolidation and Reporting

Summary
This script consolidates the OS information detected by several VTs and tries to find the best matching OS.
Furthermore it reports all previously collected information leading to this best matching OS. It also reports possible additional information which might help to improve the OS detection.
If any of this information is wrong or could be improved please consider to report these to the referenced community forum.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
Best matching OS:
OS:           Linux/Unix
CPE:          cpe:/o:linux:kernel
Found by VT:  1.3.6.1.4.1.25623.1.0.102011 (SMB NativeLanMan)
Concluded from SMB/Samba banner on port 445/tcp:
OS String:  Windows 6.1
SMB String: Samba 4.5.9
Note: The service is running on a Linux/Unix based OS but reporting itself with
↪an Windows related OS string.
Setting key "Host/runs_unixoide" based on this information
```

Solution:

Log Method
Details: `OS Detection Consolidation and Reporting`
OID:1.3.6.1.4.1.25623.1.0.105937
Version used: `2026-01-21T05:50:46Z`

References
`url: https://forum.greenbone.net/c/vulnerability-tests/7`

Log (CVSS: 0.0)
NVT: IP Forwarding Enabled - Active Check

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
Checks if the remote host has IP forwarding enabled.

Quality of Detection (QoD): 70%

Vulnerability Detection Result
`It was possible to route a TCP packet through the target host and received an an`
`↪swer which means IP forwarding is enabled.`

Solution:

Log Method
Sends a crafted Local Link Layer (LLL) frame and checks the response.
Details: `IP Forwarding Enabled - Active Check`
OID:1.3.6.1.4.1.25623.1.0.147205
Version used: `2021-12-03T08:27:06Z`

References
`cve: CVE-1999-0511`

[return to 172.30.4.1]

2.1.8 Log 445/tcp

Log (CVSS: 0.0)
NVT: SMB Login Successful For Authenticated Checks

Summary
It was possible to login using the provided SMB credentials. Hence authenticated checks are enabled.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
Vulnerability was detected according to the Vulnerability Detection Method.

Solution:

Log Method
Details: `SMB Login Successful For Authenticated Checks`
OID:1.3.6.1.4.1.25623.1.0.108539
Version used: `2023-07-28T16:09:07Z`

Log (CVSS: 0.0)
NVT: Microsoft Windows SMB Accessible Shares

Summary
The script detects the Windows SMB Accessible Shares and sets the result into KB.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
```
The following shares were found
IPC$
```

Solution:

Log Method
Details: `Microsoft Windows SMB Accessible Shares`
OID:1.3.6.1.4.1.25623.1.0.902425
Version used: `2025-04-16T05:39:43Z`

Log (CVSS: 0.0)
NVT: SMB log in

Summary
This script attempts to logon into the remote host using login/password credentials.

Quality of Detection (QoD): 97%

Vulnerability Detection Result
```
It was possible to log into the remote host using the SMB protocol.
```

Solution:

Log Method
Details: `SMB log in`
OID:1.3.6.1.4.1.25623.1.0.10394
Version used: `2025-09-25T05:39:09Z`

Log (CVSS: 0.0)
NVT: SMB NativeLanMan

Summary
It is possible to extract OS, domain and SMB server information from the Session Setup AndX Response packet which is generated during NTLM authentication.

. . . continues on next page . . .

. . . continued from previous page . . .

Quality of Detection (QoD): 95%

Vulnerability Detection Result

```
Detected SMB workgroup: WORKGROUP
Detected SMB server: Samba 4.5.9
Detected OS: Linux/Unix
```

Solution:

Log Method

Details: `SMB NativeLanMan`
OID:1.3.6.1.4.1.25623.1.0.102011
Version used: `2024-06-25T05:05:27Z`

Log (CVSS: 0.0)
NVT: SMB Remote Version Detection

Summary

Detection of Server Message Block(SMB).
This script sends SMB Negotiation request and try to get the version from the response.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
SMBv1, SMBv2 and SMBv3 are enabled on remote target
```

Solution:

Log Method

Details: `SMB Remote Version Detection`
OID:1.3.6.1.4.1.25623.1.0.807830
Version used: `2023-07-26T05:05:09Z`

Log (CVSS: 0.0)
NVT: SMB NativeLanMan

Summary

It is possible to extract OS, domain and SMB server information from the Session Setup AndX Response packet which is generated during NTLM authentication.

Quality of Detection (QoD): 95%

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Detection Result

```
Detected Samba
Version:       4.5.9
Location:      445/tcp
CPE:           cpe:/a:samba:samba:4.5.9
Concluded from version/product identification result:
Samba 4.5.9
Extra information:
Detected SMB workgroup: WORKGROUP
Detected SMB server: Samba 4.5.9
```

Solution:

Log Method

Details: `SMB NativeLanMan`
OID:1.3.6.1.4.1.25623.1.0.102011
Version used: `2024-06-25T05:05:27Z`

Log (CVSS: 0.0)
NVT: SMB/CIFS Server Detection

Summary

This script detects whether port 445 and 139 are open and if they are running a CIFS/SMB server.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
A CIFS server is running on this port
```

Solution:

Log Method

Details: `SMB/CIFS Server Detection`
OID:1.3.6.1.4.1.25623.1.0.11011
Version used: `2023-08-01T13:29:10Z`

Log (CVSS: 0.0)
NVT: SMBv1 Enabled - Active Check

Summary

The host has enabled SMBv1 for the SMB Server.

. . . continues on next page . . .

. . . continued from previous page . . .

Quality of Detection (QoD): 80%

Vulnerability Detection Result
`SMBv1 is enabled for the SMB Server`

Solution:

Log Method
Checks if SMBv1 is enabled for the SMB Server based on the information provided by the following VT:
- SMB Remote Version Detection (OID: 1.3.6.1.4.1.25623.1.0.807830).
Details: `SMBv1 Enabled - Active Check`
OID:1.3.6.1.4.1.25623.1.0.140151
Version used: `2024-01-09T05:06:46Z`

References
`url: https://www.us-cert.gov/ncas/current-activity/2017/01/16/SMB-Security-Best-`
`↪Practices`
`url: https://support.microsoft.com/en-us/kb/2696547`
`url: https://support.microsoft.com/en-us/kb/204279`

[return to 172.30.4.1]

2.1.9 Log 139/tcp

Log (CVSS: 0.0)
NVT: SMB/CIFS Server Detection

Summary
This script detects whether port 445 and 139 are open and if they are running a CIFS/SMB server.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
`A SMB server is running on this port`

Solution:

Log Method
Details: `SMB/CIFS Server Detection`
OID:1.3.6.1.4.1.25623.1.0.11011

. . . continues on next page . . .

. . . continued from previous page . . .

Version used: 2023-08-01T13:29:10Z

[return to 172.30.4.1]

2.1.10 Log general/CPE-T

Log (CVSS: 0.0)
NVT: CPE Inventory

Summary
This routine uses information collected by other routines about CPE identities of operating systems, services and applications detected during the scan.
Note: Some CPEs for specific products might show up twice or more in the output. Background: After a product got renamed or a specific vendor was acquired by another one it might happen that a product gets a new CPE within the NVD CPE Dictionary but older entries are kept with the older CPE.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
172.30.4.1|cpe:/a:samba:samba:4.5.9
172.30.4.1|cpe:/o:linux:kernel

Solution:

Log Method
Details: CPE Inventory
OID:1.3.6.1.4.1.25623.1.0.810002
Version used: 2022-07-27T10:11:28Z

References
url: https://nvd.nist.gov/products/cpe

[return to 172.30.4.1]